

Penetration Testing Report

CASO DI STUDIO: **Raven: 1**

Debora Pucciarelli | Corso di PTEH | A.A. 2025/2026



UNIVERSITÀ DEGLI STUDI DI SALERNO
DIPARTIMENTO DI INFORMATICA

Sommario

1. Executive Summary2

2. Engagement Highlights.....3

3. Vulnerability Report.....4

4. Remediation Report.....5

5. Findings Summary.....6

6. Detailed Summary20

6.1 VULNERABILITÀ CLASSIFICATE: CRITICAL20

6.2 VULNERABILITÀ CLASSIFICATE: ALTE.....26

6.3 VULNERABILITÀ CLASSIFICATE: MEDIUM.....37

6.4 VULNERABILITÀ CLASSIFICATE: LOW.....52

References55

1. Executive Summary

Il presente documento riporta i risultati dell'attività di penetration testing condotta sulla macchina virtuale Raven, disponibile sulla piattaforma VulnHub al seguente indirizzo: <https://www.vulnhub.com/entry/raven-1,256/>.

L'obiettivo dell'analisi è stato individuare, analizzare e sfruttare le vulnerabilità presenti sul sistema al fine di ottenere l'accesso alle informazioni sensibili memorizzate sulla macchina e recuperare il contenuto dei file *flag1.txt*, *flag2.txt*, *flag3.txt* e *flag4.txt*.

L'attività di penetration testing è iniziata il 09/06/2026 e conclusa il 04/07/2026 ed è stata svolta da un unico penetration tester, autore del presente report, adottando un approccio di tipo **black box**. Prima dell'avvio delle attività, infatti, era nota esclusivamente la presenza di un sistema operativo Linux sulla macchina target, mentre informazioni fondamentali quali l'indirizzo IP, i servizi attivi e la configurazione del sistema non erano disponibili e sono state enumerate da zero.

Per l'intero processo di Penetration Testing, si è adottata la metodologia del Framework Generale per il Penetration Testing.

L'analisi ha simulato le azioni di un potenziale attaccante e ha incluso le fasi di raccolta delle informazioni, identificazione dei servizi esposti, ricerca delle vulnerabilità mediante tecniche manuali e strumenti open source, sfruttamento delle debolezze individuate, escalation dei privilegi e configurazione di meccanismi di persistenza locale per il mantenimento dell'accesso.

Nel corso delle attività sono state individuate diverse vulnerabilità che potrebbero consentire a un attaccante di ottenere accesso non autorizzato al sistema, acquisire informazioni sensibili e, in alcuni casi, compromettere completamente la macchina target. Tali vulnerabilità possono avere un impatto significativo sulla riservatezza, integrità e disponibilità delle risorse presenti sul sistema.

L'attività ha portato al recupero di tutte le flag previste dallo scenario, all'ottenimento dei privilegi di amministratore (root) e alla **configurazione con pieno successo di una backdoor automatizzata**, dimostrando l'effettiva sfruttabilità e la criticità delle vulnerabilità identificate.

Le sezioni successive descrivono nel dettaglio le attività svolte, le vulnerabilità rilevate, le tecniche di sfruttamento utilizzate e le relative contromisure di rimedio.

2. Engagement Highlights

L'attività di penetration testing è stata condotta utilizzando il sistema operativo *Kali Linux*, installato su una macchina virtuale configurata all'interno della stessa rete locale della macchina target **Raven**. Trattandosi di un progetto svolto in ambito universitario e finalizzato all'apprendimento pratico delle metodologie di sicurezza offensiva, l'analisi si è focalizzata sull'impiego approfondito di strumenti open source e software specialistici inclusi nella distribuzione Kali Linux.

Poiché la macchina target era ospitata all'interno di un ambiente di laboratorio controllato, non è stato necessario definire specifici canali di comunicazione tra il penetration tester e il cliente, né stabilire particolari limitazioni operative riguardanti l'impatto delle attività svolte.

Al termine della fase di sfruttamento delle vulnerabilità, sono state effettuate alcune operazioni di post-exploitation con finalità esclusivamente didattiche, tra cui l'escalation dei privilegi e la configurazione di meccanismi di persistenza per simulare il mantenimento dell'accesso da parte di un potenziale attaccante. Tutte le attività eseguite sono state rigorosamente documentate nel file ***PT_Metodologie-Raven***.

La metodologia adottata segue il tradizionale approccio del penetration testing e si articola nelle seguenti fasi:

- Information Gathering & Target Discovery;
- Enumeration Target & Port Scanning;
- Vulnerability Mapping;
- Target Exploitation;
- Post-Exploitation (privilege escalation);
- Post-Exploitation (maintaining access).
- Reporting

Ciascuna fase è stata eseguita in maniera sequenziale al fine di identificare le vulnerabilità presenti sulla macchina target, valutarne l'impatto e dimostrarne l'effettiva sfruttabilità.

Considerata la natura didattica dell'attività e l'assenza di soggetti terzi coinvolti, non è stato necessario definire regole di ingaggio né sottoscrivere accordi di riservatezza.

Il penetration tester ha pertanto avuto piena libertà nella scelta delle metodologie, degli strumenti e delle tecniche impiegate durante l'intero processo di valutazione della sicurezza.

3. Vulnerability Report

Le vulnerabilità individuate sulla macchina target **Raven** durante il processo di Penetration Testing possono essere suddivise e classificate in due categorie principali:

- **Vulnerabilità causate da errori di configurazione del sistema:** comprendono debolezze derivanti da configurazioni errate o eccessivamente permissive che espongono il sistema ad attacchi esterni, consentendo a un attaccante di accedere a informazioni sensibili o ottenere privilegi elevati;
- **Vulnerabilità relative a software obsoleti o non aggiornati presenti nel sistema:** riguardano servizi e applicazioni che utilizzano versioni non più supportate o affette da vulnerabilità note, potenzialmente sfruttabili per compromettere il sistema.

Le principali vulnerabilità dovute a errori di configurazione riscontrate sono:

- **Enumerazione degli utenti e gestione non sicura delle credenziali:** l'analisi del CMS WordPress ha consentito di identificare utenti validi presenti sul sistema e di recuperare credenziali sensibili memorizzate in modo non sicuro. Inoltre, l'utilizzo di password deboli ha permesso l'ottenimento di accessi non autorizzati e ha favorito le successive fasi della compromissione;
- **Configurazione errata dei privilegi sudo:** una configurazione non sicura dei privilegi consentiva l'esecuzione di programmi con diritti elevati, permettendo l'escalation dei privilegi fino all'acquisizione dei diritti di root sul sistema;
- **Esposizione di informazioni sensibili :** l'applicazione web rendeva accessibili informazioni, tra cui dati presenti nel codice sorgente, che avrebbero dovuto essere protette, inoltre è stato possibile recuperare credenziali di accesso al database MySQL memorizzate in chiaro nel file di configurazione, agevolando le fasi successive dell'attacco.

Per quanto riguarda le maggiori vulnerabilità dovute a software obsoleti ritrovate sono:

- **Versione sistema operativo non aggiornata:** la macchina Raven utilizza *Debian Linux* 8, una versione non più supportata dal produttore e priva di aggiornamenti di sicurezza ufficiali, con conseguente aumento del rischio di compromissione;
- **Versione server web:** La versione installata è datata e nota per essere affetta da diverse vulnerabilità di sicurezza documentate, rendendo il server web un potenziale punto di ingresso per attacchi.
- **Versione WordPress obsoleta:** il CMS utilizza la versione di *WordPress 4.8.7*, la quale è affetta da vulnerabilità che un utente malintenzionato potrebbe sfruttare per compromettere l'applicazione web o ottenere informazioni utili nelle successive fasi dell'attacco;
- **Versione obsoleta libreria web:** la versione della librerie web utilizzata è vulnerabile a diverse tipologie di attacchi Cross-Site Scripting permettendo l'esecuzione di codice JavaScript arbitrario nel browser degli utenti e compromettendo la sicurezza dell'applicazione web.
- **Versione libreria PHPMailer:** La versione in uso presenta una falla critica nella gestione dei parametri di invio delle email. Questa debolezza ha rappresentato il vettore d'attacco principale, consentendo l'esecuzione di comandi arbitrari sul server.

La combinazione di tali vulnerabilità ha consentito la costruzione di una catena di attacco completa che ha portato all'ottenimento dell'accesso iniziale al sistema e alla successiva acquisizione dei privilegi di amministratore.

4. Remediation Report

L'attività di Penetration Testing ha evidenziato la presenza di diverse vulnerabilità che espongono la macchina Raven:1 ad un elevato rischio di compromissione. Per ridurre la superficie di attacco e migliorare il livello complessivo di sicurezza del sistema, si raccomanda di intervenire prioritariamente sulle vulnerabilità a criticità più elevata, procedendo successivamente con la correzione delle vulnerabilità di gravità inferiore. In particolare, si suggerisce di adottare le seguenti contromisure:

- Aggiornare il sistema operativo Debian ad una versione attualmente supportata e mantenuta dal produttore, al fine di ricevere regolarmente aggiornamenti e patch di sicurezza.
- Aggiornare WordPress, jQuery , PHPMailer e tutti i componenti software installati alle versioni più recenti e supportate, eliminando le vulnerabilità note associate a software obsoleti.
- Implementare una politica di gestione delle password più rigorosa, imponendo l'utilizzo di password complesse e resistenti agli attacchi a dizionario e brute force.
- Limitare o impedire l'enumerazione degli utenti WordPress, riducendo le informazioni ottenibili da utenti non autenticati durante la fase di ricognizione.
- Rimuovere dal codice sorgente e dai file di configurazione tutte le informazioni sensibili accessibili agli utenti, evitando la memorizzazione in chiaro di credenziali e dati riservati.
- Revisionare la configurazione dei privilegi sudo applicando il principio del minimo privilegio evitando che utenti non amministrativi possano eseguire programmi con privilegi elevati.
- Configurare correttamente il server web per includere header di sicurezza (come X-Frame-Options, Content-Security-Policy e X-Content-Type-Options) per mitigare attacchi lato client.
- Effettuare periodicamente attività di Vulnerability Assessment e Security Audit per identificare tempestivamente nuove vulnerabilità e verificare il rispetto delle politiche di sicurezza adottate.
- Definire una procedura di aggiornamento e manutenzione periodica del sistema, in modo da garantire il costante aggiornamento dei servizi e delle applicazioni installate.

5. Findings Summary

In questa sezione sono elencate le vulnerabilità individuate.
Sulla base della ricerca manuale, consultando CVEdetails per la versione di *Apache http Server 2.4.10* sono elencate di seguito le vulnerabilità *potenzialmente associate* [1].

CVE-2017-3167 In Apache httpd 2.2.x before 2.2.33 and 2.4.x before 2.4.26, use of the ap_get_basic_auth_pw() by third-party modules outside of the authentication phase may lead to authentication requirements being bypassed. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 20.33% 2017-06-20 2026-05-13
CVE-2017-3169 In Apache httpd 2.2.x before 2.2.33 and 2.4.x before 2.4.26, mod_ssl may dereference a NULL pointer when third-party modules call ap_hook_process_connection() during an HTTP request to an HTTPS port. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 19.95% 2017-06-20 2026-05-13
CVE-2017-7679 In Apache httpd 2.2.x before 2.2.33 and 2.4.x before 2.4.26, mod_mime can read one byte past the end of a buffer when sending a malicious Content-Type response header. Source: Apache Software Foundation	Potential exploit Max CVSS EPSS Score Published Updated	9.8 39.34% 2017-06-20 2026-05-13
CVE-2018-1312 In Apache httpd 2.2.x to 2.4.29, when generating an HTTP Digest authentication challenge, the nonce sent to prevent replay attacks was not correctly generated using a pseudo-random seed. In a cluster of servers using a common Digest authentication configuration, HTTP requests could be replayed across servers by an attacker without detection. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 15.89% 2018-03-26 2022-09-07
CVE-2021-26691 In Apache HTTP Server versions 2.4.0 to 2.4.46 a specially crafted SessionHeader sent by an origin server could cause a heap overflow Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 68.07% 2021-06-10 2022-03-25
CVE-2021-39275 ap_escape_quotes() may write beyond the end of a buffer when given malicious input. No included modules pass untrusted data to these functions, but third-party / external modules may. This issue affects Apache HTTP Server 2.4.48 and earlier. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 36.34% 2021-09-16 2025-05-01
CVE-2021-44790 A carefully crafted request body can cause a buffer overflow in the mod_lua multipart parser (r:parsebody()) called from Lua scripts). The Apache httpd team is not aware of an exploit for the vulnerability though it might be possible to craft one. This issue affects Apache HTTP Server 2.4.51 and earlier. Source: Apache Software Foundation	Potential exploit Max CVSS EPSS Score Published Updated	9.8 97.11% 2021-12-20 2025-05-01
CVE-2022-22720 Apache HTTP Server 2.4.52 and earlier fails to close inbound connection when errors are encountered discarding the request body, exposing the server to HTTP Request Smuggling Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 28.19% 2022-03-14 2022-11-02
CVE-2022-23943 Out-of-bounds Write vulnerability in mod_sed of Apache HTTP Server allows an attacker to overwrite heap memory with possibly attacker provided data. This issue affects Apache HTTP Server 2.4 version 2.4.52 and prior versions. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 50.40% 2022-03-14 2025-05-01
CVE-2022-31813 Apache HTTP Server 2.4.53 and earlier may not send the X-Forwarded-* headers to the origin server based on client side Connection header hop-by-hop mechanism. This may be used to bypass IP based authentication on the origin server/application. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 3.14% 2022-06-09 2025-05-01
CVE-2023-25690 Some mod_proxy configurations on Apache HTTP Server versions 2.4.0 through 2.4.55 allow a HTTP Request Smuggling attack. Configurations are affected when mod_proxy is enabled along with some form of RewriteRule or ProxyPassMatch in which a non-specific pattern matches some portion of the user-supplied request-target (URL) data and is then re-inserted into the proxied request-target using variable substitution. For example, something like: RewriteEngine on RewriteRule ^*/here/(.*) "http://example.com:8080/elsewhere/\$1"; [P] ProxyPassReverse /here/ Source: Apache Software Foundation	Potential exploit Max CVSS EPSS Score Published Updated	9.8 83.77% 2023-03-07 2025-12-18
CVE-2024-38474 Substitution encoding issue in mod_rewrite in Apache HTTP Server 2.4.59 and earlier allows attacker to execute scripts in directories permitted by the configuration but not directly reachable by any URL or source disclosure of scripts meant to only to be executed as CGI. Users are recommended to upgrade to version 2.4.60, which fixes this issue. Some RewriteRules that capture and substitute unsafely will now fail unless rewrite flag "UnsafeAllow3F" is specified. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 2.46% 2024-07-01 2025-03-25
CVE-2024-38476 Vulnerability in core of Apache HTTP Server 2.4.59 and earlier are vulnerably to information disclosure, SSRF or local script execution via backend applications whose response headers are malicious or exploitable. Users are recommended to upgrade to version 2.4.60, which fixes this issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	9.8 41.61% 2024-07-01 2025-11-03

CVE-2026-28780 Heap-based Buffer Overflow vulnerability in mod_proxy_ajp of Apache HTTP Server. If mod_proxy_ajp connects to a malicious AJP server this AJP server can send a malicious AJP message back to mod_proxy_ajp and cause it to write 4 attacker controlled bytes after the end of a heap based buffer. This issue affects Apache HTTP Server: through 2.4.66. Users are recommended to upgrade to version 2.4.67, which fixes the issue. Source: Apache Software Foundation	Max CVSS 9.8 EPSS Score 0.72% Published 2026-05-05 Updated 2026-05-06
CVE-2026-29167 Use After Free vulnerability in Apache HTTP Server with mod_lidap in per-directory configuration This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue. Source: Apache Software Foundation	Max CVSS 9.8 EPSS Score 0.66% Published 2026-06-08 Updated 2026-06-09
CVE-2026-44631 Buffer Underwrite vulnerability in Apache HTTP Server on crafted regular expressions in the configuration. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue. Source: Apache Software Foundation	Max CVSS 9.8 EPSS Score 0.49% Published 2026-06-08 Updated 2026-06-11
CVE-2017-9788 In Apache httpd before 2.2.34 and 2.4.x before 2.4.27, the value placeholder in [Proxy-]Authorization headers of type 'Digest' was not initialized or reset before or between successive key=value assignments by mod_auth_digest. Providing an initial key with no '=' assignment could reflect the stale value of uninitialized pool memory used by the prior request, leading to leakage of potentially confidential information, and a segfault in other cases resulting in denial of service. Source: Apache Software Foundation	Max CVSS 9.1 EPSS Score 56.77% Published 2017-07-13 Updated 2026-05-13
CVE-2022-22721 If LimitXMLRequestBody is set to allow request bodies larger than 350MB (defaults to 1M) on 32 bit systems an integer overflow happens which later causes out of bounds writes. This issue affects Apache HTTP Server 2.4.52 and earlier. Source: Apache Software Foundation	Max CVSS 9.1 EPSS Score 41.86% Published 2022-03-14 Updated 2022-11-02
CVE-2022-28615 Apache HTTP Server 2.4.53 and earlier may crash or disclose information due to a read beyond bounds in ap_strcmp_match() when provided with an extremely large input buffer. While no code distributed with the server can be coerced into such a call, third-party modules or lua scripts that use ap_strcmp_match() may hypothetically be affected. Source: Apache Software Foundation	Max CVSS 9.1 EPSS Score 5.69% Published 2022-06-09 Updated 2025-12-18
CVE-2024-38475 Improper escaping of output in mod_rewrite in Apache HTTP Server 2.4.59 and earlier allows an attacker to map URLs to filesystem locations that are permitted to be served by the server but are not intentionally/directly reachable by any URL, resulting in code execution or source code disclosure. Substitutions in server context that use a backreferences or variables as the first segment of the substitution are affected. Some unsafe RewriteRules will be broken by this change and the rewrite flag "UnsafePrefixStat" can be used to opt back in once ensuring the substitution is appropriately constrained. Source: Apache Software Foundation	Max CVSS 9.1 EPSS Score 99.96% Published 2024-07-01 Updated 2025-11-17 CISA KEV Added 2025-05-01
CVE-2024-40898 SSRF in Apache HTTP Server on Windows with mod_rewrite in server/vhost context, allows to potentially leak NTLM hashes to a malicious server via SSRF and malicious requests. Users are recommended to upgrade to version 2.4.62 which fixes this issue. Source: Apache Software Foundation	Max CVSS 9.1 EPSS Score 1.54% Published 2024-07-18 Updated 2024-08-08
CVE-2026-42535 A path handling issue in mod_dav_fs in Apache 2.4.67 and earlier allows a WebDAV content author to directly manipulate trusted DAV property databases, potentially causing child process crashes. Users are recommended to upgrade to version 2.4.68, which fixes this issue. Source: Apache Software Foundation	Max CVSS 9.1 EPSS Score 0.54% Published 2026-06-08 Updated 2026-06-09
CVE-2021-40438 A crafted request uri-path can cause mod_proxy to forward the request to an origin server chosen by the remote user. This issue affects Apache HTTP Server 2.4.48 and earlier. Source: Apache Software Foundation	Max CVSS 9.0 EPSS Score 100.00% Published 2021-09-16 Updated 2025-10-27 CISA KEV Added 2021-12-01
CVE-2022-36760 Inconsistent Interpretation of HTTP Requests ('HTTP Request Smuggling') vulnerability in mod_proxy_ajp of Apache HTTP Server allows an attacker to smuggle requests to the AJP server it forwards requests to. This issue affects Apache HTTP Server Apache HTTP Server 2.4 version 2.4.54 and prior versions. Source: Apache Software Foundation	Max CVSS 9.0 EPSS Score 1.88% Published 2023-01-17 Updated 2024-11-21
CVE-2026-24072 An escalation of privilege bug in various modules in Apache HTTP 2.4.66 and earlier allows local .htaccess authors to read files with the privileges of the httpd user. Users are recommended to upgrade to version 2.4.67, which fixes this issue. Source: Apache Software Foundation	Max CVSS 8.8 EPSS Score 0.65% Published 2026-05-04 Updated 2026-05-04
CVE-2025-58098 Apache HTTP Server 2.4.65 and earlier with Server Side Includes (SSI) enabled and mod_cgid (but not mod_cgi) passes the shell-escaped query string to #exec cmd="..." directives. This issue affects Apache HTTP Server before 2.4.66. Users are recommended to upgrade to version 2.4.66, which fixes the issue. Source: Apache Software Foundation	Max CVSS 8.3 EPSS Score 1.50% Published 2025-12-05 Updated 2025-12-08
CVE-2016-5387 The Apache HTTP Server through 2.4.23 follows RFC 3875 section 4.1.18 and therefore does not protect applications from the presence of untrusted client data in the HTTP_PROXY environment variable, which might allow remote attackers to redirect an application's outbound HTTP traffic to an arbitrary proxy server via a crafted Proxy header in an HTTP request, aka an "httpoxy" issue. NOTE: the vendor states "This mitigation has been assigned the identifier CVE-2016-5387"; in other words, this is not a CVE ID for a vulnerability. Source: Red Hat, Inc.	Max CVSS 8.1 EPSS Score 55.72% Published 2016-07-19 Updated 2026-05-06

CVE-2017-15715		Max CVSS	8.1
In Apache httpd 2.4.0 to 2.4.29, the expression specified in <FilesMatch> could match '\$' to a newline character in a malicious filename, rather than matching only the end of the filename. This could be exploited in environments where uploads of some files are externally blocked, but only by matching the trailing portion of the filename.		EPSS Score	86.01%
Source: Apache Software Foundation		Published	2018-03-26
		Updated	2021-06-06
CVE-2024-38473	🔪 Potential exploit	Max CVSS	8.1
Encoding problem in mod_proxy in Apache HTTP Server 2.4.59 and earlier allows request URLs with incorrect encoding to be sent to backend services, potentially bypassing authentication via crafted requests. Users are recommended to upgrade to version 2.4.60, which fixes this issue.		EPSS Score	25.88%
Source: Apache Software Foundation		Published	2024-07-01
		Updated	2025-07-01
CVE-2006-20001		Max CVSS	7.5
A carefully crafted If: request header can cause a memory read, or write of a single zero byte, in a pool (heap) memory location beyond the header value sent. This could cause the process to crash. This issue affects Apache HTTP Server 2.4.54 and earlier.		EPSS Score	3.55%
Source: Apache Software Foundation		Published	2023-01-17
		Updated	2025-02-13
CVE-2016-0736		Max CVSS	7.5
In Apache HTTP Server versions 2.4.0 to 2.4.23, mod_session_crypto was encrypting its data/cookie using the configured ciphers with possibly either CBC or ECB modes of operation (AES256-CBC by default), hence no selectable or builtin authenticated encryption. This made it vulnerable to padding oracle attacks, particularly with CBC.		EPSS Score	48.02%
Source: Apache Software Foundation		Published	2017-07-27
		Updated	2026-05-13
CVE-2016-2161		Max CVSS	7.5
In Apache HTTP Server versions 2.4.0 to 2.4.23, malicious input to mod_auth_digest can cause the server to crash, and each instance continues to crash even for subsequently valid requests.		EPSS Score	20.95%
Source: Apache Software Foundation		Published	2017-07-27
		Updated	2026-05-13
CVE-2016-8743		Max CVSS	7.5
Apache HTTP Server, in all releases prior to 2.2.32 and 2.4.25, was liberal in the whitespace accepted from requests and sent in response lines and headers. Accepting these different behaviors represented a security concern when httpd participates in any chain of proxies or interacts with back-end application servers, either through mod_proxy or using conventional CGI mechanisms, and may result in request smuggling, response splitting and cache pollution.		EPSS Score	13.25%
Source: Apache Software Foundation		Published	2017-07-27
		Updated	2026-05-13
CVE-2017-9798	🔴 Public exploit	Max CVSS	7.5
Apache httpd allows remote attackers to read secret data from process memory if the Limit directive can be set in a user's .htaccess file, or if httpd.conf has certain misconfigurations, aka Optionsbleed. This affects the Apache HTTP Server through 2.2.34 and 2.4.x through 2.4.27. The attacker sends an unauthenticated OPTIONS HTTP request when attempting to read secret data. This is a use-after-free issue and thus secret data is not always sent, and the specific data depends on many factors including configuration. Exploitation with .htaccess can be blocked with a patch to the ap_limit_section		EPSS Score	95.00%
Source: Apache Software Foundation		Published	2017-09-18
		Updated	2026-05-13
CVE-2017-15710		Max CVSS	7.5
In Apache httpd 2.0.23 to 2.0.65, 2.2.0 to 2.2.34, and 2.4.0 to 2.4.29, mod_authnz_ldap, if configured with AuthLDAPCharsetConfig, uses the Accept-Language header value to lookup the right charset encoding when verifying the user's credentials. If the header value is not present in the charset conversion table, a fallback mechanism is used to truncate it to a two characters value to allow a quick retry (for example, 'en-US' is truncated to 'en'). A header value of less than two characters forces an out of bound write of one NUL byte to a memory location that is not part of the string. In		EPSS Score	18.20%
Source: Apache Software Foundation		Published	2018-03-26
		Updated	2021-06-06
CVE-2018-1303		Max CVSS	7.5
A specially crafted HTTP request header could have crashed the Apache HTTP Server prior to version 2.4.30 due to an out of bound read while preparing data to be cached in shared memory. It could be used as a Denial of Service attack against users of mod_cache_socache. The vulnerability is considered as low risk since mod_cache_socache is not widely used, mod_cache_disk is not concerned by this vulnerability.		EPSS Score	70.78%
		Published	2018-03-26
		Updated	2021-06-06
CVE-2018-17199		Max CVSS	7.5
In Apache HTTP Server 2.4 release 2.4.37 and prior, mod_session checks the session expiry time before decoding the session. This causes session expiry time to be ignored for mod_session_cookie sessions since the expiry time is loaded when the session is decoded.		EPSS Score	19.99%
Source: Apache Software Foundation		Published	2019-01-30
		Updated	2021-06-06
CVE-2019-0217		Max CVSS	7.5
In Apache HTTP Server 2.4 release 2.4.38 and prior, a race condition in mod_auth_digest when running in a threaded server could allow a user with valid credentials to authenticate using another username, bypassing configured access control restrictions.		EPSS Score	18.65%
Source: Apache Software Foundation		Published	2019-04-08
		Updated	2021-06-06
CVE-2021-26690		Max CVSS	7.5
Apache HTTP Server versions 2.4.0 to 2.4.46 A specially crafted Cookie header handled by mod_session can cause a NULL pointer dereference and crash, leading to a possible Denial Of Service		EPSS Score	65.07%
Source: Apache Software Foundation		Published	2021-06-10
		Updated	2021-12-01
CVE-2021-34798		Max CVSS	7.5
Malformed requests may cause the server to dereference a NULL pointer. This issue affects Apache HTTP Server 2.4.48 and earlier.		EPSS Score	64.51%
Source: Apache Software Foundation		Published	2021-09-16
		Updated	2022-10-28

CVE-2022-22719		Max CVSS	7.5
A carefully crafted request body can cause a read to a random memory area which could cause the process to crash. This issue affects Apache HTTP Server 2.4.52 and earlier. Source: Apache Software Foundation		EPSS Score	69.80%
		Published	2022-03-14
		Updated	2022-11-02
CVE-2022-26377	🚫 Potential exploit	Max CVSS	7.5
Inconsistent Interpretation of HTTP Requests ('HTTP Request Smuggling') vulnerability in mod_proxy_ajp of Apache HTTP Server allows an attacker to smuggle requests to the AJP server it forwards requests to. This issue affects Apache HTTP Server Apache HTTP Server 2.4 version 2.4.53 and prior versions. Source: Apache Software Foundation		EPSS Score	18.89%
		Published	2022-06-09
		Updated	2025-05-01
CVE-2022-29404		Max CVSS	7.5
In Apache HTTP Server 2.4.53 and earlier, a malicious request to a lua script that calls r:parsebody(0) may cause a denial of service due to no default limit on possible input size. Source: Apache Software Foundation		EPSS Score	5.64%
		Published	2022-06-09
		Updated	2022-08-24
CVE-2022-30556		Max CVSS	7.5
Apache HTTP Server 2.4.53 and earlier may return lengths to applications calling r:wsread() that point past the end of the storage allocated for the buffer. Source: Apache Software Foundation		EPSS Score	4.66%
		Published	2022-06-09
		Updated	2025-05-01
CVE-2023-31122		Max CVSS	7.5
Out-of-bounds Read vulnerability in mod_macro of Apache HTTP Server.This issue affects Apache HTTP Server: through 2.4.57. Source: Apache Software Foundation		EPSS Score	2.98%
		Published	2023-10-23
		Updated	2025-08-01
CVE-2024-38477		Max CVSS	7.5
null pointer dereference in mod_proxy in Apache HTTP Server 2.4.59 and earlier allows an attacker to crash the server via a malicious request. Users are recommended to upgrade to version 2.4.60, which fixes this issue. Source: Apache Software Foundation		EPSS Score	3.15%
		Published	2024-07-01
		Updated	2025-11-03
CVE-2024-39573		Max CVSS	7.5
Potential SSRF in mod_rewrite in Apache HTTP Server 2.4.59 and earlier allows an attacker to cause unsafe RewriteRules to unexpectedly setup URL's to be handled by mod_proxy. Users are recommended to upgrade to version 2.4.60, which fixes this issue. Source: Apache Software Foundation		EPSS Score	35.45%
		Published	2024-07-01
		Updated	2025-11-03
CVE-2024-42516		Max CVSS	7.5
HTTP response splitting in the core of Apache HTTP Server allows an attacker who can manipulate the Content-Type response headers of applications hosted or proxied by the server can split the HTTP response. This vulnerability was described as CVE-2023-38709 but the patch included in Apache HTTP Server 2.4.59 did not address the issue. Users are recommended to upgrade to version 2.4.64, which fixes this issue. Source: Apache Software Foundation		EPSS Score	0.68%
		Published	2025-07-10
		Updated	2025-11-04
CVE-2024-43204		Max CVSS	7.5
SSRF in Apache HTTP Server with mod_proxy loaded allows an attacker to send outbound proxy requests to a URL controlled by the attacker. Requires an unlikely configuration where mod_headers is configured to modify the Content-Type request or response header with a value provided in the HTTP request. Users are recommended to upgrade to version 2.4.64 which fixes this issue. Source: Apache Software Foundation		EPSS Score	0.77%
		Published	2025-07-10
		Updated	2025-11-04
CVE-2024-43394		Max CVSS	7.5
Server-Side Request Forgery (SSRF) in Apache HTTP Server on Windows allows to potentially leak NTLM hashes to a malicious server via mod_rewrite or apache expressions that pass unvalidated request input. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.63. Note: The Apache HTTP Server Project will be setting a higher bar for accepting vulnerability reports regarding SSRF via UNC paths. The server offers limited protection against administrators directing the server to open UNC paths. Windows servers should limit the hosts they will connect over via SMB based on the nature Source: Apache Software Foundation		EPSS Score	1.09%
		Published	2025-07-10
		Updated	2025-11-04
CVE-2024-47252		Max CVSS	7.5
Insufficient escaping of user-supplied data in mod_ssl in Apache HTTP Server 2.4.63 and earlier allows an untrusted SSL/TLS client to insert escape characters into log files in some configurations. In a logging configuration where CustomLog is used with "%(varname)x" or "%(varname)c" to log variables provided by mod_ssl such as SSL_TLS_SNI, no escaping is performed by either mod_log_config or mod_ssl and unsanitized data provided by the client may appear in log files. Source: Apache Software Foundation		EPSS Score	0.67%
		Published	2025-07-10
		Updated	2025-11-04
CVE-2024-47252		Max CVSS	7.5
Insufficient escaping of user-supplied data in mod_ssl in Apache HTTP Server 2.4.63 and earlier allows an untrusted SSL/TLS client to insert escape characters into log files in some configurations. In a logging configuration where CustomLog is used with "%(varname)x" or "%(varname)c" to log variables provided by mod_ssl such as SSL_TLS_SNI, no escaping is performed by either mod_log_config or mod_ssl and unsanitized data provided by the client may appear in log files. Source: Apache Software Foundation		EPSS Score	0.67%
		Published	2025-07-10
		Updated	2025-11-04

CVE-2026-29169 A NULL pointer dereference in mod_dav_lock in Apache HTTP Server 2.4.66 and earlier may allow an attacker to crash the server with a malicious request.mod_dav_lock is not used internally by mod_dav or mod_dav_fs. The only known use-case for mod_dav_lock was mod_dav_svn from Apache Subversion earlier than version 1.2.0. Users are recommended to upgrade to version 2.4.66, which fixes this issue, or remove mod_dav_lock. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.5 0.59% 2026-05-04 2026-05-05
CVE-2026-34355 A buffer overflow in mod_proxy_html in Apache HTTP Server 2.4.67 and earlier allows an attack by an untrusted backend. Users are recommended to upgrade to version 2.4.68, which fixes this issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.5 0.57% 2026-06-08 2026-06-09
CVE-2026-34356 Heap-based Buffer Overflow vulnerability in Apache HTTP Server with malicious backend servers and ProxyPassReverseCookie* This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.5 0.68% 2026-06-08 2026-06-09
CVE-2026-42536 Heap-based Buffer Overflow vulnerability in Apache HTTP Server with mod_xml2enc, xml2StartParse, and untrusted content This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.5 0.50% 2026-06-08 2026-06-09
CVE-2025-49812 In some mod_ssl configurations on Apache HTTP Server versions through to 2.4.63, an HTTP desynchronisation attack allows a man-in-the-middle attacker to hijack an HTTP session via a TLS upgrade. Only configurations using "SSLEngine optional" to enable TLS upgrades are affected. Users are recommended to upgrade to version 2.4.64, which removes support for TLS upgrade. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.4 0.52% 2025-07-10 2025-11-04
CVE-2020-35452 Apache HTTP Server versions 2.4.0 to 2.4.46 A specially crafted Digest nonce can cause a stack overflow in mod_auth_digest. There is no report of this overflow being exploitable, nor the Apache HTTP Server team could create one, though some particular compiler and/or compilation option might make it possible, with limited consequences anyway due to the size (a single byte) and the value (zero byte) of the overflow Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.3 53.19% 2021-06-10 2021-12-01
CVE-2023-38709  Potential exploit Faulty input validation in the core of Apache allows malicious or exploitable backend/content generators to split HTTP responses. This issue affects Apache HTTP Server: through 2.4.58. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.3 3.91% 2024-04-04 2025-11-04
CVE-2026-44185 Buffer Over-read vulnerability in Apache HTTP Server via outbound OCSP requests to an attacker controlled OCSP server This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.3 0.45% 2026-06-08 2026-06-11
CVE-2026-44186 Loop with Unreachable Exit Condition ('Infinite Loop') vulnerability in the mod_proxy_ftp module in Apache HTTP Server with an attacker controlled backend FTP server. This issue affects undefined: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	7.3 0.56% 2026-06-08 2026-06-11
CVE-2025-65082 Improper Neutralization of Escape, Meta, or Control Sequences vulnerability in Apache HTTP Server through environment variables set via the Apache configuration unexpectedly superseding variables calculated by the server for CGI programs. This issue affects Apache HTTP Server from 2.4.0 through 2.4.65. Users are recommended to upgrade to version 2.4.66 which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.5 0.76% 2025-12-05 2025-12-10
CVE-2026-43951 Out-of-bounds Read vulnerability in Apache HTTP Server with mod_headers and mod_mime and multiple response languages. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.5 0.53% 2026-06-08 2026-06-11
CVE-2024-24795 HTTP Response splitting in multiple modules in Apache HTTP Server allows an attacker that can inject malicious response headers into backend applications to cause an HTTP desynchronization attack. Users are recommended to upgrade to version 2.4.59, which fixes this issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.3 2.87% 2024-04-04 2025-06-30
CVE-2016-4975 Possible CRLF injection allowing HTTP response splitting attacks for sites which use mod_userdir. This issue was mitigated by changes made in 2.4.25 and 2.2.32 which prohibit CR or LF injection into the "Location" or other outbound header key or value. Fixed in Apache HTTP Server 2.4.25 (Affected 2.4.1-2.4.23). Fixed in Apache HTTP Server 2.2.32 (Affected 2.2.0-2.2.31). Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.1 19.80% 2018-08-14 2021-06-06
CVE-2019-10092  Potential exploit In Apache HTTP Server 2.4.0-2.4.39, a limited cross-site scripting issue was reported affecting the mod_proxy error page. An attacker could cause the link on the error page to be malformed and instead point to a page of their choice. This would only be exploitable where a server was set up with proxying enabled but was misconfigured in such a way that the Proxy Error page was displayed. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.1 81.47% 2019-09-26 2021-09-09

CVE-2019-10098 In Apache HTTP server 2.4.0 to 2.4.39, Redirects configured with mod_rewrite that were intended to be self-referential might be fooled by encoded newlines and redirect instead to an unexpected URL within the request URL. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.1 73.98% 2019-09-25 2021-06-14
CVE-2020-1927 In Apache HTTP Server 2.4.0 to 2.4.41, redirects configured with mod_rewrite that were intended to be self-referential might be fooled by encoded newlines and redirect instead to an an unexpected URL within the request URL. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.1 56.89% 2020-04-0 2022-07-21
CVE-2026-29170 A cross-site scripting vulnerability exists in mod_proxy_ftp's HTML directory list generation in Apache HTTP Server 2.4.67 and earlier when listing FTP directory contents either via forward or reverse proxy configuration. Users are recommended to upgrade to version 2.4.68, which fixes this issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	6.1 0.50% 2026-06-0 2026-06-0
CVE-2018-1301 A specially crafted request could have crashed the Apache HTTP Server prior to version 2.4.30, due to an out of bound access after a size limit is reached by reading the HTTP header. This vulnerability is considered very hard if not impossible to trigger in non-debug mode (both log and build level), so it is classified as low risk for common server usage. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.9 15.56% 2018-03-26 2021-06-06
CVE-2018-1302 When an HTTP/2 stream was destroyed after being handled, the Apache HTTP Server prior to version 2.4.30 could have written a NULL pointer potentially to an already freed memory. The memory pools maintained by the server make this vulnerability hard to trigger in usual configurations, the reporter and the team could not reproduce it outside debug builds, so it is classified as low risk. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.9 13.44% 2018-03-26 2021-06-06
Page: 4    Copy		
CVE-2020-13938 Apache HTTP Server versions 2.4.0 to 2.4.46 Unprivileged local users can stop httpd on Windows Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.5 11.77% 2021-06-10 2022-04-15
CVE-2026-44119 Improper Privilege Management vulnerability in Apache HTTP Server 2.4.67 and earlier allows local .htaccess authors to read files with the privileges of the httpd user. This issue affects Apache HTTP Server: from through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.5 0.17% 2026-06-08 2026-06-11
CVE-2018-1283 In Apache httpd 2.4.0 to 2.4.29, when mod_session is configured to forward its session data to CGI applications (SessionEnv on, not the default), a remote user may influence their content by using a "Session" header. This comes from the "HTTP_SESSION" variable name used by mod_session to forward its data to CGIs, since the prefix "HTTP_" is also used by the Apache HTTP Server to pass HTTP header fields, per CGI specifications. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 10.12% 2018-03-26 2021-06-06
CVE-2019-0220 A vulnerability was found in Apache HTTP Server 2.4.0 to 2.4.38. When the path component of a request URL contains multiple consecutive slashes ('/'), directives such as LocationMatch and RewriteRule must account for duplicates in regular expressions while other aspects of the servers processing will implicitly collapse them. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 17.86% 2019-06-11 2022-07-25
CVE-2020-11985 IP address spoofing when proxying using mod_remoteip and mod_rewrite For configurations using proxying with mod_remoteip and certain mod_rewrite rules, an attacker could spoof their IP address for logging and PHP scripts. Note this issue was fixed in Apache HTTP Server 2.4.24 but was retrospectively allocated a low severity CVE in 2020. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 5.88% 2020-08-07 2021-06-06
CVE-2022-28330 Apache HTTP Server 2.4.53 and earlier on Windows may read beyond bounds when configured to process requests with the mod_isapi module. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 3.38% 2022-06-09 2022-06-24
CVE-2022-28614 The ap_rwrite() function in Apache HTTP Server 2.4.53 and earlier may read unintended memory if an attacker can cause the server to reflect very large input using ap_rwrite() or ap_rputs(), such as with mod_lua's rputs() function. Modules compiled and distributed separately from Apache HTTP Server that use the 'ap_rputs' function and may pass it a very large (INT_MAX or larger) string must be compiled against current headers to resolve the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 4.40% 2022-06-09 2022-08-24
CVE-2022-37436 Prior to Apache HTTP Server 2.4.55, a malicious backend can cause the response headers to be truncated early, resulting in some headers being incorporated into the response body. If the later headers have any security purpose, they will not be interpreted by the client. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 57.94% 2023-01-17 2024-11-21
CVE-2026-33007 A NULL pointer dereference in the mod_authn_socache in Apache HTTP Server 2.4.66 and earlier allows an unauthenticated remote user to crash a child process in a caching forward proxy configuration. Users are recommended to upgrade to version 2.4.67, which fixes this issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 0.51% 2026-05-04 2026-05-04

CVE-2026-33007 A NULL pointer dereference in the mod_authn_socache in Apache HTTP Server 2.4.66 and earlier allows an unauthenticated remote user to crash a child process in a caching forward proxy configuration. Users are recommended to upgrade to version 2.4.67, which fixes this issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 0.51% 2026-05-04 2026-05-04
CVE-2026-33857 Out-of-bounds Read vulnerability in mod_proxy_ajp of Apache HTTP Server. This issue affects Apache HTTP Server: through 2.4.66. Users are recommended to upgrade to version 2.4.67, which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 0.39% 2026-05-04 2026-05-04
CVE-2026-34032 Improper Null Termination, Out-of-bounds Read vulnerability in Apache HTTP Server. This issue affects Apache HTTP Server: through 2.4.66. Users are recommended to upgrade to version 2.4.67, which fixes the issue. Source: Apache Software Foundation	Max CVSS EPSS Score Published Updated	5.3 0.49% 2026-05-04 2026-05-04
CVE-2013-5704  Potential exploit The mod_headers module in the Apache HTTP Server 2.2.22 allows remote attackers to bypass "RequestHeader unset" directives by placing a header in the trailer portion of data sent with chunked transfer coding. NOTE: the vendor states "this is not a security issue in httpd as such." Source: MITRE	Max CVSS EPSS Score Published Updated	5.0 60.21% 2014-04-15 2026-05-06
CVE-2014-3581 The cache_merge_headers_out function in modules/cache/cache_util.c in the mod_cache module in the Apache HTTP Server before 2.4.11 allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via an empty HTTP Content-Type header. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	5.0 13.21% 2014-10-10 2026-05-06
CVE-2014-3583 The handle_headers function in mod_proxy_fcgi.c in the mod_proxy_fcgi module in the Apache HTTP Server 2.4.10 allows remote FastCGI servers to cause a denial of service (buffer over-read and daemon crash) via long response headers. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	5.0 10.50% 2014-12-15 2026-05-06
CVE-2015-0228 The lua_websocket_read function in lua_request.c in the mod_lua module in the Apache HTTP Server through 2.4.12 allows remote attackers to cause a denial of service (child-process crash) by sending a crafted WebSocket Ping frame after a Lua script has called the wsupgrade function. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	5.0 18.81% 2015-03-08 2026-05-06
CVE-2015-3183 The chunked transfer coding implementation in the Apache HTTP Server before 2.4.14 does not properly parse chunk headers, which allows remote attackers to conduct HTTP request smuggling attacks via a crafted request, related to mishandling of large chunk-size values and invalid chunk-extension characters in modules/http/http_filters.c. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	5.0 73.33% 2015-07-20 2026-05-06
CVE-2014-8109 mod_lua.c in the mod_lua module in the Apache HTTP Server 2.3.x and 2.4.x through 2.4.10 does not support an httpd configuration in which the same Lua authorization provider is used with different arguments within different contexts, which allows remote attackers to bypass intended access restrictions in opportunistic circumstances by leveraging multiple Require directives, as demonstrated by a configuration that specifies authorization for one group to access a certain directory, and authorization for a second group to access a second directory. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	4.3 22.02% 2014-12-29 2026-05-06
CVE-2015-3185 The ap_some_auth_required function in server/request.c in the Apache HTTP Server 2.4.x before 2.4.14 does not consider that a Require directive may be associated with an authorization setting rather than an authentication setting, which allows remote attackers to bypass intended access restrictions in opportunistic circumstances by leveraging the presence of a module that relies on the 2.2 API behavior. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	4.3 18.80% 2015-07-20 2026-05-06
CVE-2016-8612 Apache HTTP Server mod_cluster before version httpd 2.4.23 is vulnerable to an Improper Input Validation in the protocol parsing logic in the load balancer resulting in a Segmentation Fault in the serving httpd process. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	4.3 4.69% 2018-03-09 2023-02-12

Per la versione *OpenSSH 6.7pi* sono elencate le seguenti vulnerabilità *potenzialmente associate* [2]:

CVE-2026-35414 OpenSSH before 10.3 mishandles the authorized_keys principals option in uncommon scenarios involving a principals list in conjunction with a Certificate Authority that makes certain use of comma characters. Source: MITRE	Max CVSS 8.1 EPSS Score 0.35% Published 2026-04-02 Updated 2026-04-10
CVE-2026-35388 OpenSSH before 10.3 omits connection multiplexing confirmation for proxy-mode multiplexing sessions. Source: MITRE	Max CVSS 2.5 EPSS Score 0.00% Published 2026-04-02 Updated 2026-04-27
CVE-2026-35387 OpenSSH before 10.3 can use unintended ECDSA algorithms. Listing of any ECDSA algorithm in PubkeyAcceptedAlgorithms or HostbasedAcceptedAlgorithms is misinterpreted to mean all ECDSA algorithms. Source: MITRE	Max CVSS 6.5 EPSS Score 0.24% Published 2026-04-02 Updated 2026-04-27
CVE-2026-35386 In OpenSSH before 10.3, command execution can occur via shell metacharacters in a username within a command line. This requires a scenario where the username on the command line is untrusted, and also requires a non-default configurations of % in ssh_config. Source: MITRE	Max CVSS 8.1 EPSS Score 0.25% Published 2026-04-02 Updated 2026-04-27
CVE-2026-35385 In OpenSSH before 10.3, a file downloaded by scp may be installed setuid or setgid, an outcome contrary to some users' expectations, if the download is performed as root with -O (legacy scp protocol) and without -p (preserve mode). Source: MITRE	Max CVSS 8.1 EPSS Score 0.29% Published 2026-04-02 Updated 2026-04-27
CVE-2025-61985 ssh in OpenSSH before 10.1 allows the '\0' character in an ssh:// URI, potentially leading to code execution when a ProxyCommand is used. Source: MITRE	Max CVSS 3.6 EPSS Score 0.01% Published 2025-10-06 Updated 2025-10-08
CVE-2025-61984 ssh in OpenSSH before 10.1 allows control characters in usernames that originate from certain possibly untrusted sources, potentially leading to code execution when a ProxyCommand is used. The untrusted sources are the command line and %-sequence expansion of a configuration file. (A configuration file that provides a complete literal username is not categorized as an untrusted source.) Source: MITRE	Max CVSS 3.6 EPSS Score 0.22% Published 2025-10-06 Updated 2025-11-11
CVE-2023-51385  Potential exploit In ssh in OpenSSH before 9.6, OS command injection might occur if a user name or host name has shell metacharacters, and this name is referenced by an expansion token in certain situations. For example, an untrusted Git repository can have a submodule with shell metacharacters in a user name or host name. Source: MITRE	Max CVSS 6.5 EPSS Score 19.75% Published 2023-12-18 Updated 2026-05-12
CVE-2023-48795  Potential exploit The SSH transport protocol with certain OpenSSH extensions, found in OpenSSH before 9.6 and other products, allows remote attackers to bypass integrity checks such that some packets are omitted (from the extension negotiation message), and a client and server may consequently end up with a connection for which some security features have been downgraded or disabled, aka a Terrapin attack. This occurs because the SSH Binary Packet Protocol (BPP), implemented by these extensions, mishandles the handshake phase and mishandles use of sequence numbers. For Source: MITRE	Max CVSS 5.9 EPSS Score 93.31% Published 2023-12-18 Updated 2026-05-12

CVE-2021-41617		Max CVSS	7.0
sshd in OpenSSH 6.2 through 8.x before 8.8, when certain non-default configurations are used, allows privilege escalation because supplemental groups are not initialized as expected. Helper programs for AuthorizedKeysCommand and AuthorizedPrincipalsCommand may run with privileges associated with group memberships of the sshd process, if the configuration specifies running the command as a different user.		EPSS Score	2.37%
Source: MITRE		Published	2021-09-26
		Updated	2026-05-12
CVE-2021-36368		Max CVSS	3.7
An issue was discovered in OpenSSH before 8.9. If a client is using public-key authentication with agent forwarding but without -oLogLevel=verbose, and an attacker has silently modified the server to support the None authentication option, then the user cannot determine whether FIDO authentication is going to confirm that the user wishes to connect to that server, or that the user wishes to allow that server to connect to a different server on the user's behalf. NOTE: the vendor's position is "this is not an authentication bypass, since nothing is being bypassed."		EPSS Score	1.68%
Source: MITRE		Published	2022-03-13
		Updated	2026-05-29
CVE-2020-15778	 Potential exploit	Max CVSS	7.8
scp in OpenSSH through 8.3p1 allows command injection in the scp.c toremote function, as demonstrated by backtick characters in the destination argument. NOTE: the vendor reportedly has stated that they intentionally omit validation of "anomalous argument transfers" because that could "stand a great chance of breaking existing workflows."		EPSS Score	13.00%
Source: MITRE		Published	2020-07-24
		Updated	2025-07-28
CVE-2020-14145		Max CVSS	5.9
The client side in OpenSSH 5.7 through 8.4 has an Observable Discrepancy leading to an information leak in the algorithm negotiation. This allows man-in-the-middle attackers to target initial connection attempts (where no host key for the server has been cached by the client). NOTE: some reports state that 8.5 and 8.6 are also affected.		EPSS Score	2.06%
Source: MITRE		Published	2020-06-29
		Updated	2025-12-18
CVE-2019-6111	 Potential exploit	Max CVSS	5.9
An issue was discovered in OpenSSH 7.9. Due to the scp implementation being derived from 1983 rcp, the server chooses which files/directories are sent to the client. However, the scp client only performs cursory validation of the object name returned (only directory traversal attacks are prevented). A malicious scp server (or Man-in-The-Middle attacker) can overwrite arbitrary files in the scp client target directory. If recursive operation (-r) is performed, the server can manipulate subdirectories as well (for example, to overwrite the .ssh/authorized_keys file).		EPSS Score	58.20%
Source: MITRE		Published	2019-01-31
		Updated	2025-12-18
CVE-2019-6110	 Potential exploit	Max CVSS	6.8
In OpenSSH 7.9, due to accepting and displaying arbitrary stderr output from the server, a malicious server (or Man-in-The-Middle attacker) can manipulate the client output, for example to use ANSI control codes to hide additional files being transferred.		EPSS Score	20.91%
Source: MITRE		Published	2019-01-31
		Updated	2025-12-18
CVE-2019-6109		Max CVSS	6.8
An issue was discovered in OpenSSH 7.9. Due to missing character encoding in the progress display, a malicious server (or Man-in-The-Middle attacker) can employ crafted object names to manipulate the client output, e.g., by using ANSI control codes to hide additional files being transferred. This affects refresh_progress_meter() in progressmeter.c.		EPSS Score	3.81%
Source: MITRE		Published	2019-01-31
		Updated	2026-05-28
CVE-2018-20685		Max CVSS	5.3
In OpenSSH 7.9, scp.c in the scp client allows remote SSH servers to bypass intended access restrictions via the filename of . or an empty filename. The impact is modifying the permissions of the target directory on the client side.		EPSS Score	3.69%
Source: MITRE		Published	2019-01-10
		Updated	2025-12-17
CVE-2018-15919		Max CVSS	5.3
Remotely observable behaviour in auth-gss2.c in OpenSSH through 7.8 could be used by remote attackers to detect existence of users on a target system when GSS2 is in use. NOTE: the discoverer states 'We understand that the OpenSSH developers do not want to treat such a username enumeration (or "oracle") as a vulnerability.'		EPSS Score	3.56%
Source: MITRE		Published	2018-08-28
		Updated	2025-12-18
CVE-2018-15473	 Public exploit	Max CVSS	5.9
OpenSSH through 7.7 is prone to a user enumeration vulnerability due to not delaying bailout for an invalid authenticating user until after the packet containing the request has been fully parsed, related to auth2-gss.c, auth2-hostbased.c, and auth2-pubkey.c.		EPSS Score	98.63%
Source: MITRE		Published	2018-08-17
		Updated	2025-12-17
CVE-2017-15906		Max CVSS	5.3
The process_open function in sftp-server.c in OpenSSH before 7.6 does not properly prevent write operations in readonly mode, which allows attackers to create zero-length files.		EPSS Score	3.36%
Source: MITRE		Published	2017-10-26
		Updated	2026-05-28
CVE-2016-20012	 Potential exploit	Max CVSS	5.3
OpenSSH through 8.7 allows remote attackers, who have a suspicion that a certain combination of username and public key is known to an SSH server, to test whether this suspicion is correct. This occurs because a challenge is sent only when that combination could be valid for a login session. NOTE: the vendor does not recognize user enumeration as a vulnerability for this product		EPSS Score	5.04%
Source: MITRE		Published	2021-09-15
		Updated	2026-05-29

CVE-2016-10708 ssh in OpenSSH before 7.4 allows remote attackers to cause a denial of service (NULL pointer dereference and daemon crash) via an out-of-sequence NEWKEYS message, as demonstrated by Honggfuzz, related to kex.c and packet.c. Source: MITRE	Max CVSS EPSS Score Published Updated	7.5 16.00% 2018-01-21 2026-04-29
CVE-2016-10012 The shared memory manager (associated with pre-authentication compression) in sshd in OpenSSH before 7.4 does not ensure that a bounds check is enforced by all compilers, which might allows local users to gain privileges by leveraging access to a sandboxed privilege-separation process, related to the m_zback and m_zlib data structures. Source: MITRE	Max CVSS EPSS Score Published Updated	7.8 1.28% 2017-01-05 2026-05-29
CVE-2016-10011 authfile.c in sshd in OpenSSH before 7.4 does not properly consider the effects of realloc on buffer contents, which might allow local users to obtain sensitive private-key information by leveraging access to a privilege-separated child process. Source: MITRE	Max CVSS EPSS Score Published Updated	6.2 1.10% 2017-01-05 2026-05-29
CVE-2016-10010 sshd in OpenSSH before 7.4, when privilege separation is not used, creates forwarded Unix-domain sockets as root, which might allow local users to gain privileges via unspecified vectors, related to serverloop.c. Source: MITRE	Max CVSS EPSS Score Published Updated	7.0 4.24% 2017-01-05 2026-05-29
CVE-2016-10009 Untrusted search path vulnerability in ssh-agent.c in ssh-agent in OpenSSH before 7.4 allows remote attackers to execute arbitrary local PKCS#11 modules by leveraging control over a forwarded agent-socket. Source: MITRE	Max CVSS EPSS Score Published Updated	7.5 37.43% 2017-01-05 2026-05-29
CVE-2016-3115 Multiple CRLF injection vulnerabilities in session.c in sshd in OpenSSH before 7.2p2 allow remote authenticated users to bypass intended shell-command restrictions via crafted X11 forwarding data, related to the (1) do_authenticated1 and (2) session_x11_req functions. Source: MITRE	Max CVSS EPSS Score Published Updated	6.4 37.02% 2016-03-22 2026-05-29
CVE-2016-1908 The client in OpenSSH before 7.2 mishandles failed cookie generation for untrusted X11 forwarding and relies on the local X11 server for access-control decisions, which allows remote X11 clients to trigger a fallback and obtain trusted X11 forwarding privileges by leveraging configuration issues on this X11 server, as demonstrated by lack of the SECURITY extension on this X11 server. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	9.8 13.74% 2017-04-11 2026-05-29
CVE-2016-0778  Potential exploit The (1) roaming_read and (2) roaming_write functions in roaming_common.c in the client in OpenSSH 5.x, 6.x, and 7.x before 7.1p2, when certain proxy and forward options are enabled, do not properly maintain connection file descriptors, which allows remote servers to cause a denial of service (heap-based buffer overflow) or possibly have unspecified other impact by requesting many forwardings. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	8.1 20.37% 2016-01-14 2026-05-29
CVE-2016-0777 The resend_bytes function in roaming_common.c in the client in OpenSSH 5.x, 6.x, and 7.x before 7.1p2 allows remote servers to obtain sensitive information from process memory by requesting transmission of an entire buffer, as demonstrated by reading a private key. Source: Red Hat, Inc.	Max CVSS EPSS Score Published Updated	6.5 63.47% 2016-01-14 2026-05-29
CVE-2015-6564 Use-after-free vulnerability in the mm_answer_pam_free_ctx function in monitor.c in sshd in OpenSSH before 7.0 on non-OpenBSD platforms might allow local users to gain privileges by leveraging control of the sshd uid to send an unexpectedly early MONITOR_REQ_PAM_FREE_CTX request. Source: MITRE	Max CVSS EPSS Score Published Updated	7.0 0.60% 2015-08-24 2026-05-27
CVE-2015-6563 The monitor component in sshd in OpenSSH before 7.0 on non-OpenBSD platforms accepts extraneous username data in MONITOR_REQ_PAM_INIT_CTX requests, which allows local users to conduct impersonation attacks by leveraging any SSH login access in conjunction with control of the sshd uid to send a crafted MONITOR_REQ_PWNAM request, related to monitor.c and monitor_wrap.c. Source: MITRE	Max CVSS EPSS Score Published Updated	6.4 0.38% 2015-08-24 2026-05-27
CVE-2015-5600  Potential exploit The kbdint_next_device function in auth2-chall.c in sshd in OpenSSH through 6.9 does not properly restrict the processing of keyboard-interactive devices within a single connection, which makes it easier for remote attackers to conduct brute-force attacks or cause a denial of service (CPU consumption) via a long and duplicative list in the ssh -oKbdInteractiveDevices option, as demonstrated by a modified client that provides a different password for each pam element on this list. Source: MITRE	Max CVSS EPSS Score Published Updated	8.5 9.30% 2015-08-03 2026-05-27
CVE-2015-5352 The x11_open_helper function in channels.c in ssh in OpenSSH before 6.9, when ForwardX11Trusted mode is not used, lacks a check of the refusal deadline for X connections, which makes it easier for remote attackers to bypass intended access restrictions via a connection outside of the permitted time window. Source: MITRE	Max CVSS EPSS Score Published Updated	4.3 5.45% 2015-08-03 2026-05-06

Per la versione *libreria PHPMailer 5.2.16* sono elencate le seguenti vulnerabilità *potenzialmente associate* [3]:

🚩 CVE-2016-10033 Detail

Description

The mailSend function in the isMail transport in PHPMailer before 5.2.18 might allow remote attackers to pass extra parameters to the mail command and consequently execute arbitrary code via a `"` (backslash double quote) in a crafted Sender property.

Metrics CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **NIST: NVD**

Base Score: 8.8 **CRITICAL**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

 **ADP: CISA ADP**

Base Score: 8.8 **CRITICAL**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

QUICK INFO

CVE Dictionary Entry:

[CVE-2016-10033](#)

NVD Published Date:

12/30/2016

NVD Last Modified:

06/16/2026

Source:

MITRE

Per la versione *4.8.7 del CMS WordPress* sono elencate le seguenti vulnerabilità *potenzialmente associate* [4]:

🚩 CVE-2018-20147 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

In WordPress before 4.9.9 and 5.x before 5.0.1, authors could modify metadata to bypass intended restrictions on deleting files.

Metrics CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **NIST: NVD**

Base Score: 6.5 **MEDIUM**

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

QUICK INFO

CVE Dictionary Entry:

[CVE-2018-20147](#)

NVD Published Date:

12/14/2018

NVD Last Modified:

06/16/2026

Source:

MITRE

🚩 CVE-2018-20148 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

In WordPress before 4.9.9 and 5.x before 5.0.1, contributors could conduct PHP object injection attacks via crafted metadata in a wp_getdataitem XMLHttpRequest call. This is caused by mishandling of serialized data at `phar://` URLs in the `wp_get_attachment_thumb_file` function in `wp-includes/post.php`.

Metrics CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **NIST: NVD**

Base Score: 8.8 **CRITICAL**

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

QUICK INFO

CVE Dictionary Entry:

[CVE-2018-20148](#)

NVD Published Date:

12/14/2018

NVD Last Modified:

06/16/2026

Source:

MITRE

🚩 CVE-2018-20153 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

In WordPress before 4.9.9 and 5.x before 5.0.1, contributors could modify new comments made by users with greater privileges, possibly causing XSS.

Metrics CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **NIST: NVD**

Base Score: 5.4 **MEDIUM**

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N

QUICK INFO

CVE Dictionary Entry:

[CVE-2018-20153](#)

NVD Published Date:

12/14/2018

NVD Last Modified:

06/16/2026

Source:

MITRE

CVE-2018-20152 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

In WordPress before 4.9.9 and 5.x before 5.0.1, authors could bypass intended restrictions on post types via crafted input.

Metrics CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **NIST: NVD**

Base Score: 6.5 **MEDIUM**

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

QUICK INFO

CVE Dictionary Entry:

[CVE-2018-20152](#)

NVD Published Date:

12/14/2018

NVD Last Modified:

06/16/2026

Source:

MITRE

CVE-2018-20151 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

In WordPress before 4.9.9 and 5.x before 5.0.1, the user-activation page could be read by a search engine's web crawler if an unusual configuration were chosen. The search engine could then index and display a user's e-mail address and (rarely) the password that was generated by default.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: **5.9 Medium**

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

QUICK INFO

CVE Dictionary Entry:

CVE-2018-20151

NVD Published Date:

12/14/2018

NVD Last Modified:

06/16/2026

Source:

MITRE

CVE-2018-20150 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

In WordPress before 4.9.9 and 5.x before 5.0.1, crafted URLs could trigger XSS for certain use cases involving plugins.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: **5.4 Medium**

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:N/A:N

QUICK INFO

CVE Dictionary Entry:

CVE-2018-20150

NVD Published Date:

12/14/2018

NVD Last Modified:

06/16/2026

Source:

MITRE

CVE-2018-20149 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

In WordPress before 4.9.9 and 5.x before 5.0.1, when the Apache HTTP Server is used, authors could upload crafted files that bypass intended MIME type restrictions, leading to XSS, as demonstrated by a .jpg file without JPEG data.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: **5.4 Medium**

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

QUICK INFO

CVE Dictionary Entry:

CVE-2018-20149

NVD Published Date:

12/14/2018

NVD Last Modified:

06/16/2026

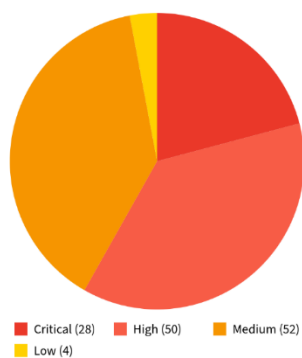
Source:

MITRE

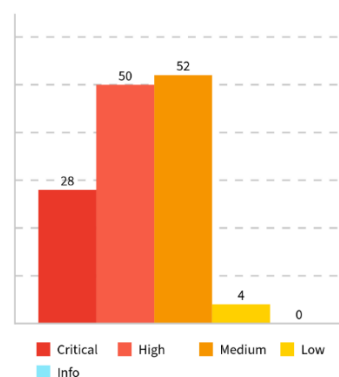
Considerandole classificazioni CVSS fornite dai rispettivi report le vulnerabilità possono essere così suddivise:

- Livello Critico (9.0-10.0): 28 vulnerabilità individuate;
- Livello Alto (7.0-8.9): 50 vulnerabilità individuate;
- Livello Medio (4.0-6.9): 52 vulnerabilità individuate;
- Livello Basso (0.1-3.9): 4 vulnerabilità individuate;
- Livello Info (0.0): 0 vulnerabilità individuate

In totale sono presenti 134 vulnerabilità.



Critical	20,90%
Hight	37,31%
Medium	38,81%
Low	2,98%
Info	0%



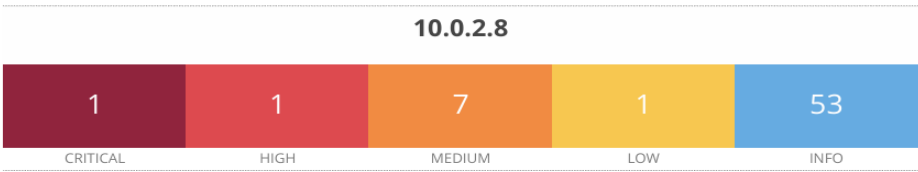
L’attività di Vulnerability Assesment automatizzata è stata condotta mediante due strumenti distinti: *Nessus* e *OWASP ZAP*.

Per quanto riguarda *Nessus*, è stata presa in considerazione la scansione “*Scan for all web vulnerabilities (complex)*”, in quanto più completa e focalizzata sull’analisi delle vulnerabilità applicative del sistema target.

Vulnerabilities					Total: 57
SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	10.0	-	-	201420	Debian Linux SEoL (8.x)
HIGH	7.5*	-	-	42423	CGI Generic SSI Injection (HTTP headers)
MEDIUM	6.1	5.7	0.439	136929	jQuery 1.2 < 3.5.0 Multiple XSS
MEDIUM	5.9	6.1	0.5261	187315	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
MEDIUM	5.3	2.2	0.0053	10756	Apple Mac OS X Find-By-Content .DS_Store Web Directory Lis
MEDIUM	5.3	-	-	40984	Browsable Web Directories
MEDIUM	5.0*	-	-	57640	Web Application Information Disclosure
MEDIUM	4.3*	-	-	85582	Web Application Potentially Vulnerable to Clickjacking
MEDIUM	5.0*	-	-	90067	WordPress User Enumeration
LOW	2.1*	2.2	0.0037	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	-	10223	RPC portmapper Service Detection
INFO	N/A	-	-	18261	Apache Banner Linux Distribution Disclosure
INFO	N/A	-	-	48204	Apache HTTP Server Version
INFO	N/A	-	-	39520	Backported Security Patch Detection (SSH)
INFO	N/A	-	-	39521	Backported Security Patch Detection (WWW)
INFO	N/A	-	-	33817	CGI Generic Tests Load Estimation (all tests)
INFO	N/A	-	-	39470	CGI Generic Tests Timeout
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	132634	Deprecated SSLv2 Connection Attempts
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	35716	Ethernet Card Manufacturer Detection
INFO	N/A	-	-	86420	Ethernet MAC Addresses
INFO	N/A	-	-	49704	External URLs
INFO	N/A	-	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	-	10107	HTTP Server Type and Version
INFO	N/A	-	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	-	14788	IP Protocols Scan
INFO	N/A	-	-	106658	jQuery Detection
INFO	N/A	-	-	50344	Missing or Permissive Content-Security-Policy frame-ancesto HTTP Response Header
INFO	N/A	-	-	50345	Missing or Permissive X-Frame-Options HTTP Response Heac
INFO	N/A	-	-	11219	Nessus SYN scanner
INFO	N/A	-	-	19506	Nessus Scan Information
INFO	N/A	-	-	209654	OS Fingerprints Detected
INFO	N/A	-	-	11936	OS Identification
INFO	N/A	-	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	-	181418	OpenSSH Detection
INFO	N/A	-	-	66334	Patch Report
INFO	N/A	-	-	11111	RPC Services Enumeration
INFO	N/A	-	-	53335	RPC portmapper (TCP)
INFO	N/A	-	-	277650	Remote Services Not Using Post-Quantum Ciphers
INFO	N/A	-	-	70657	SSH Algorithms and Languages Supported
INFO	N/A	-	-	149334	SSH Password Authentication Accepted
INFO	N/A	-	-	10881	SSH Protocol Versions Supported
INFO	N/A	-	-	153588	SSH SHA-1 HMAC Algorithms Enabled
INFO	N/A	-	-	10267	SSH Server Type and Version Information
INFO	N/A	-	-	22964	Service Detection
INFO	N/A	-	-	298387	Shor's Harvest Now Decrypt Later
INFO	N/A	-	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	-	10287	Traceroute Information
INFO	N/A	-	-	91815	Web Application Sitemap
INFO	N/A	-	-	11032	Web Server Directory Enumeration
INFO	N/A	-	-	49705	Web Server Harvested Email Addresses
INFO	N/A	-	-	10662	Web mirroring
INFO	N/A	-	-	18297	WordPress Detection
INFO	N/A	-	-	101841	WordPress Outdated Plugin Detection
INFO	N/A	-	-	101842	WordPress Plugin Detection

* indicates the v3.0 score was not available; the v2.0 score is shown

Sono state individuate 63 vulnerabilità così classificate:



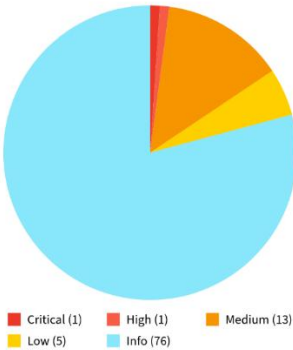
OWASP ZAP ha invece permesso di effettuare un'analisi dinamica dell'applicazione web, individuando complessivamente 33 segnalazioni relative a vulnerabilità e problematiche di sicurezza.

Alert type	Risk	Count		
Absence of Anti-CSRF Tokens	Medium	2 (6.1%)	Tech Detected - Google Font API	Informational 1 (3.0%)
Content Security Policy (CSP) Header Not Set	Medium	5 (15.2%)	Tech Detected - Google Maps	Informational 1 (3.0%)
HTTP to HTTPS Insecure Transition in Form Post	Medium	8 (24.2%)	Tech Detected - Magnific Popup	Informational 1 (3.0%)
Missing Anti-clickjacking Header	Medium	5 (15.2%)	Tech Detected - OWL Carousel	Informational 1 (3.0%)
Sub Resource Integrity Attribute Missing	Medium	5 (15.2%)	Tech Detected - PHP	Informational 1 (3.0%)
Vulnerable JS Library	Medium	2 (6.1%)	Tech Detected - Popper	Informational 1 (3.0%)
Cross-Domain JavaScript Source File Inclusion	Low	5 (15.2%)	Tech Detected - RSS	Informational 1 (3.0%)
In Page Banner Information Leak	Low	5 (15.2%)	Tech Detected - Twenty Seventeen	Informational 1 (3.0%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	5 (15.2%)	Tech Detected - Vimeo	Informational 1 (3.0%)
X-Content-Type-Options Header Missing	Low	5 (15.2%)	Tech Detected - WordPress	Informational 1 (3.0%)
Information Disclosure - Suspicious Comments	Informational	5 (15.2%)	Tech Detected - YouTube	Informational 1 (3.0%)
Modern Web Application	Informational	5 (15.2%)	Tech Detected - cdnjs	Informational 1 (3.0%)
Tech Detected - Animate.css	Informational	1 (3.0%)	Tech Detected - jQuery	Informational 1 (3.0%)
Tech Detected - Apache HTTP Server	Informational	1 (3.0%)	Tech Detected - jQuery Migrate	Informational 1 (3.0%)
Tech Detected - Bootstrap	Informational	1 (3.0%)	Tech Detected - parallax.js	Informational 1 (3.0%)
Tech Detected - Debian	Informational	1 (3.0%)	User Controllable HTML Element Attribute (Potential XSS)	Informational 1 (3.0%)
Tech Detected - Font Awesome	Informational	1 (3.0%)	Total	33

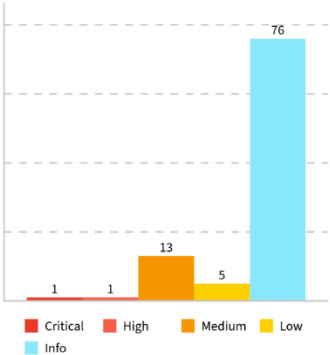
		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://10.0.2.8	0 (0)	6 (6)	4 (10)	23 (33)

Combinando i risultati ottenuti dai due strumenti e considerando le classificazioni CVSS fornite dai rispettivi report, le segnalazioni rilevate possono essere raggruppate per livello come segue:

- **Livello Critico:** 1 vulnerabilità individuata;
- **Livello Alto :** 1 vulnerabilità individuata;
- **Livello Medio :** 13 vulnerabilità individuate;
- **Livello Basso :** 5 vulnerabilità individuate;
- **Livello Informativo:** 76 vulnerabilità individuate.



Critical	1,04%
Hight	1,04%
Medium	13,54%
Low	5,21%
Info	79,17%



Per un totale di **96** vulnerabilità individuate.

6. Detailed Summary

6.1 VULNERABILITÀ CLASSIFICATE: CRITICAL

Identificativo/ Livello:	CVE-2017-3167 / CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Nelle versioni di Apache httpd precedenti alla 2.2.33 e precedenti alla 2.4.26, l'utilizzo della funzione <code>ap_get_basic_auth_pw()</code> da parte di moduli di terze parti al di fuori della fase di autenticazione potrebbe consentire di eludere i requisiti di autenticazione.
Impatto:	Un attaccante remoto può accedere a risorse protette senza autenticarsi, compromettendo riservatezza, integrità e disponibilità del sistema.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.26 o successiva (oppure 2.2.33 per il ramo 2.2) e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2017-3167 https://www.cvedetails.com/cve/CVE-2017-3167/

Identificativo/ Livello:	CVE-2017-3169 / CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Nelle versioni di Apache httpd precedenti alla 2.2.33 e precedenti alla 2.4.26, <code>mod_ssl</code> potrebbe dereferenziare un puntatore NULL quando i moduli di terze parti chiamano <code>ap_hook_process_connection()</code> durante una richiesta HTTP a una porta HTTPS.
Impatto:	Un attaccante remoto può provocare un Denial of Service (DoS), rendendo il server web temporaneamente non disponibile.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.26 o successiva (oppure 2.2.33 per il ramo 2.2) e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2017-3169 https://www.cvedetails.com/cve/CVE-2017-3169/

Identificativo/ Livello:	CVE-2017-7679/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Nelle versioni di Apache httpd 2.2.x precedenti alla 2.2.33 e 2.4.x precedenti alla 2.4.26, <code>mod_mime</code> può leggere un byte oltre la fine di un buffer quando invia un'intestazione di risposta Content-Type dannosa.
Impatto:	Un attaccante remoto può causare un comportamento imprevisto del server, con possibili compromissioni della riservatezza, integrità e disponibilità del sistema.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.26 o successiva (oppure 2.2.33 per il ramo 2.2) e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2017-7679 https://www.cvedetails.com/cve/CVE-2017-7679/

Identificativo/ Livello:	CVE-2018-1312/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Nelle versioni di Apache httpd dalla 2.2.0 alla 2.4.29, durante la generazione di una richiesta di autenticazione HTTP Digest, il nonce inviato per prevenire gli attacchi di risposta non veniva generato correttamente utilizzando un seed pseudo-casuale. In un cluster di server che utilizzavano una configurazione di autenticazione Digest comune, le richieste HTTP potevano essere riprodotte su più server da un utente malintenzionato senza essere rilevato.
Impatto:	Un attaccante può riutilizzare richieste di autenticazione valide per ottenere accessi non autorizzati ai server del cluster.
Soluzione:	Aggiornare Apache HTTP Server a una versione successiva alla 2.4.29 (o applicare le patch di sicurezza ufficiali).
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2018-1312 https://www.cvedetails.com/cve/CVE-2018-1312/

Identificativo/ Livello:	CVE-2021-26691/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Nelle versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.46, un SessionHeader

	appositamente creato e inviato da un server di origine potrebbe causare un overflow dell'heap.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per compromettere la riservatezza, l'integrità e la disponibilità del sistema.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.48 o successiva, applicando le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2021-26691 https://www.cvedetails.com/cve/CVE-2021-26691/

Identificativo/ Livello:	CVE-2021-39275/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	La funzione ap_escape_quotes() potrebbe scrivere oltre la fine di un buffer se riceve input dannosi. Nessun modulo incluso passa dati non attendibili a queste funzioni, ma moduli di terze parti/esterni potrebbero farlo. Questo problema riguarda Apache HTTP Server 2.4.48 e versioni precedenti.
Impatto:	Un attaccante remoto può compromettere la riservatezza, l'integrità e la disponibilità del sistema sfruttando la vulnerabilità.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.49 o successiva, applicando le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2021-39275 https://www.cvedetails.com/cve/CVE-2021-39275/

Identificativo/ Livello:	CVE-2022-22720/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Apache HTTP Server 2.4.52 e versioni precedenti non riescono a chiudere la connessione in entrata quando si verificano errori, scartando il corpo della richiesta ed esponendo il server al HTTP Request Smuggling.
Impatto:	Un attaccante remoto può manipolare le richieste HTTP, aggirare controlli di sicurezza e compromettere la riservatezza, l'integrità e la disponibilità del sistema.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.53 o successiva e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2022-22720 https://www.cvedetails.com/cve/CVE-2022-22720/

Identificativo/ Livello:	CVE-2022-23943/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Una vulnerabilità di scrittura fuori dai limiti nella variabile mod_sed del server HTTP Apache consente a un utente malintenzionato di sovrascrivere la memoria heap con dati potenzialmente forniti dall'attaccante stesso. Questo problema interessa Apache HTTP Server 2.4 versione 2.4.52 e versioni precedenti.
Impatto:	Un attaccante remoto può compromettere la riservatezza, l'integrità e la disponibilità del sistema, con possibile esecuzione di codice arbitrario o crash del server.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.53 o successiva, applicando le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2022-23943/ https://www.cvedetails.com/cve/CVE-2022-23943/

Identificativo/ Livello:	CVE-2022-31813/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Apache HTTP Server 2.4.53 e versioni precedenti potrebbero non inviare le intestazioni X-Forwarded-* al server di origine in base al meccanismo hop-by-hop dell'intestazione Connection lato client. Questo potrebbe essere utilizzato per aggirare l'autenticazione basata su IP sul server/applicazione di origine.
Impatto:	Un attaccante remoto può bypassare l'autenticazione basata su IP e ottenere l'accesso a risorse protette.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.54 o successiva e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale

Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2022-31813 https://www.cvedetails.com/cve/CVE-2022-31813/
--------------	--

Identificativo/ Livello:	CVE-2023-25690/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Alcune configurazioni di mod_proxy nelle versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.55 consentono un attacco di HTTP Request Smuggling. Le configurazioni sono interessate quando mod_proxy è abilitato insieme a una qualche forma di RewriteRule o ProxyPassMatch in cui un pattern non specifico corrisponde a una parte dei dati request-target (URL) forniti dall'utente e viene quindi reinserito nel request-target del proxy tramite sostituzione di variabili. Ad esempio, qualcosa del tipo: RewriteEngine on RewriteRule "^/here/(.*)" "http://example.com:8080/elsewhere?\${1}"; [P] ProxyPassReverse /here/ http://example.com:8080/ Lo splitting/smuggling delle richieste potrebbe comportare l'elusione dei controlli di accesso nel server proxy, il proxying di URL indesiderati verso server di origine esistenti e l'avvelenamento della cache. Si raccomanda agli utenti di aggiornare Apache HTTP Server almeno alla versione 2.4.56.
Impatto:	Un attaccante remoto può aggirare i controlli di accesso, inoltrare richieste non autorizzate ai server di origine ed effettuare cache poisoning.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.56 o successiva e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2023-25690 https://www.cvedetails.com/cve/CVE-2023-25690/

Identificativo/ Livello:	CVE-2024-38474/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Un problema di codifica di sostituzione in mod_rewrite in Apache HTTP Server 2.4.59 e versioni precedenti consente a un utente malintenzionato di eseguire script in directory consentite dalla configurazione ma non direttamente raggiungibili tramite URL, oppure di divulgare il codice sorgente di script destinati a essere eseguiti solo come CGI. Si consiglia agli utenti di aggiornare alla versione 2.4.60, che risolve questo problema. Alcune RewriteRules che catturano e sostituiscono in modo non sicuro ora falliranno a meno che non venga specificato il flag di riscrittura "UnsafeAllow3F".
Impatto:	Un attaccante remoto può eseguire script non autorizzati o ottenere informazioni sensibili, compromettendo riservatezza, integrità e disponibilità del sistema.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.60 o successiva e verificare le regole RewriteRule, utilizzando il flag UnsafeAllow3F solo se strettamente necessario.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2024-38474 https://www.cvedetails.com/cve/CVE-2024-38474/

Identificativo/ Livello:	CVE-2024-38476/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	La vulnerabilità nel core di Apache HTTP Server 2.4.59 e versioni precedenti espone alla divulgazione di informazioni, SSRF o all'esecuzione di script locali tramite applicazioni backend le cui intestazioni di risposta sono dannose o sfruttabili. Si consiglia agli utenti di aggiornare alla versione 2.4.60, che risolve questo problema.
Impatto:	Un attaccante remoto può ottenere informazioni sensibili, eseguire richieste verso sistemi interni o sfruttare script locali, compromettendo riservatezza, integrità e disponibilità del sistema.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.60 o successiva e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2024-38476 https://www.cvedetails.com/cve/CVE-2024-38476/

Identificativo/ Livello:	CVE-2026-28780/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Vulnerabilità di buffer overflow basata sull'heap nel modulo mod_proxy_ajp del server HTTP Apache. Se mod_proxy_ajp si connette a un server AJP malevolo, quest'ultimo può inviare un messaggio AJP dannoso a mod_proxy_ajp, causando la scrittura di 4 byte controllati dall'attaccante dopo la fine di un buffer basato sull'heap. Questo problema interessa le versioni di Apache HTTP Server fino alla 2.4.66. Si consiglia agli utenti di aggiornare alla versione 2.4.67, che risolve il problema.

Impatto:	Un attaccante remoto può compromettere la riservatezza, l'integrità e la disponibilità del sistema, con possibile esecuzione di codice arbitrario o crash del server.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.67 o successiva e applicare le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2026-28780 https://www.cvedetails.com/cve/CVE-2026-28780/

Identificativo/ Livello:	CVE-2026-29167/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Vulnerabilità di tipo Use After Free nel server HTTP Apache con mod_lidap nella configurazione per directory. Questo problema interessa le versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.67. Si consiglia agli utenti di aggiornare alla versione 2.4.68, che risolve il problema.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per compromettere riservatezza, integrità e disponibilità del sistema, con possibile esecuzione di codice arbitrario o crash del server.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.68 o successiva, applicando le patch di sicurezza ufficiali.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2026-29167 https://www.cvedetails.com/cve/CVE-2026-29167/

Identificativo/ Livello:	CVE-2026-44631/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Vulnerabilità di tipo Buffer Underwrite nel server HTTP Apache su espressioni regolari appositamente create nella configurazione. Questo problema interessa le versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.67. Si consiglia agli utenti di aggiornare alla versione 2.4.68, che risolve il problema.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per ottenere esecuzione di codice arbitrario, causando compromissione completa del sistema.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.68 o successiva, che corregge il problema, ed evitare configurazioni con regex non validate o non sicure.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2026-44631 https://www.cvedetails.com/cve/CVE-2026-44631/

Identificativo/ Livello:	CVE-2017-9788/ CVSS v3.0/v3.1: 9.1/10 (Critical)
Descrizione:	Nelle versioni di Apache httpd precedenti alla 2.2.34 e nelle versioni 2.4.x precedenti alla 2.4.27, il segnaposto del valore nelle intestazioni [Proxy-]Authorization di tipo 'Digest' non veniva inizializzato o reimpostato prima o tra successive assegnazioni chiave=valore da parte di mod_auth_digest. Fornire una chiave iniziale senza assegnazione '=' poteva riflettere il valore obsoleto della memoria del pool non inizializzata utilizzata dalla richiesta precedente, portando alla fuga di informazioni potenzialmente riservate e, in altri casi, a un errore di segmentazione con conseguente negazione del servizio.
Impatto:	Un attaccante remoto può ottenere informazioni sensibili presenti in memoria e causare Denial of Service (DoS) tramite crash del server.
Soluzione:	Aggiornare Apache HTTP Server a 2.2.34/2.4.27 o superiore 2.4.27 e disabilitare o limitare l'uso di mod_auth_digest se non necessario.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2017-9788 https://www.cvedetails.com/cve/CVE-2017-9788/

Identificativo/ Livello:	CVE-2022-22721/ CVSS v3.0/v3.1: 9.1/10 (Critical)
Descrizione:	Se LimitXMLRequestBody è impostato per consentire corpi di richiesta di dimensioni superiori a 350 MB (il valore predefinito è 1 MB) su sistemi a 32 bit, si verifica un overflow di interi che successivamente causa scritture fuori dai limiti. Questo problema interessa Apache HTTP Server 2.4.52 e versioni precedenti.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per provocare, corruzione della memoria, possibile esecuzione di codice arbitrario o Denial of Service (DoS) tramite crash del server.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.53 o successiva, dove il problema è stato corretto, ed evitare configurazioni con valori eccessivi di LimitXMLRequestBody su sistemi a 32 bit.

Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2022-22721 https://www.cvedetails.com/cve/CVE-2022-22721/

Identificativo/ Livello:	CVE-2022-28615/ CVSS v3.0/v3.1: 9.1/10 (Critical)
Descrizione:	Apache HTTP Server 2.4.53 e versioni precedenti potrebbero bloccarsi o divulgare informazioni a causa di una lettura oltre i limiti nella funzione <code>ap_strcmp_match()</code> quando viene fornito un buffer di input estremamente grande. Sebbene nessun codice distribuito con il server possa essere forzato a eseguire tale chiamata, i moduli di terze parti o gli script Lua che utilizzano <code>ap_strcmp_match()</code> potrebbero teoricamente essere interessati.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per causare Denial of Service (DoS) tramite crash del server e ottenere possibile information disclosure (lettura di memoria)
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.54 o successiva.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2022-28615 https://www.cvedetails.com/cve/CVE-2022-28615/

Identificativo/ Livello:	CVE-2024-38475/ CVSS v3.0/v3.1: 9.1/10 (Critical)
Descrizione:	Una gestione impropria dei caratteri di escape nell'output di <code>mod_rewrite</code> in Apache HTTP Server 2.4.59 e versioni precedenti consente a un utente malintenzionato di mappare gli URL a posizioni del filesystem che possono essere servite dal server ma non sono intenzionalmente/direttamente raggiungibili tramite alcun URL, con conseguente esecuzione di codice o divulgazione del codice sorgente. Le sostituzioni nel contesto del server che utilizzano riferimenti all'indietro o variabili come primo segmento della sostituzione sono interessate. Alcune regole di riscrittura non sicure saranno compromesse da questa modifica e il flag di riscrittura "UnsafePrefixStat" può essere utilizzato per riattivarlo una volta garantito che la sostituzione sia adeguatamente vincolata.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per accedere a risorse del filesystem non previste, ottenere source code disclosure e in alcuni casi, arrivare a code execution.
Soluzione:	Aggiornare Apache HTTP Server a versioni successive alla 2.4.59 / 2.4.60 (patch di sicurezza)
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2024-38475 https://www.cvedetails.com/cve/CVE-2024-38475/

Identificativo/ Livello:	CVE-2021-40438/ CVSS v3.0/v3.1: 9.0/10 (Critical)
Descrizione:	Un percorso URI di richiesta appositamente creato può indurre <code>mod_proxy</code> a inoltrare la richiesta a un server di origine scelto dall'utente remoto. Questo problema riguarda Apache HTTP Server 2.4.48 e versioni precedenti.
Impatto:	Un attaccante remoto può forzare il server a effettuare richieste verso sistemi interni o esterni E esporre servizi non pubblici (es. rete interna).
Soluzione:	Aggiornare Apache HTTP Server alla versione successiva alla 2.4.48
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2021-40438 https://www.cvedetails.com/cve/CVE-2021-40438/

Identificativo/ Livello:	CVE-2022-36760/ CVSS v3.0/v3.1: 9.0/10 (Critical)
Descrizione:	La vulnerabilità di interpretazione incoerente delle richieste HTTP ('HTTP Request Smuggling') presente nel modulo <code>mod_proxy_ajp</code> del server HTTP Apache consente a un utente malintenzionato di instradare le richieste verso il server AJP a cui vengono inoltrate. Questo problema interessa le versioni di Apache HTTP Server 2.4, 2.4.54 e precedenti.
Impatto:	Un attaccante remoto può inviare richieste HTTP appositamente costruite per bypassare controlli di sicurezza, interferire con richieste di altri utenti e eseguire attacchi come session hijacking o cache poisoning.
Soluzione:	Aggiornare Apache HTTP Server a una versione successiva alla 2.4.54 ($\geq 2.4.55$) e disabilitare <code>mod_proxy_ajp</code> se non necessario.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2022-36760 https://www.cvedetails.com/cve/CVE-2022-36760/

Identificativo/ Livello:	CVE-2016-1908/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 7.2, il client gestisce in modo errato la generazione non riuscita dei cookie per l'inoltro X11 non attendibile e si affida al server X11 locale per le decisioni di controllo degli accessi. Ciò consente ai client X11 remoti di attivare un meccanismo di fallback e ottenere privilegi di inoltro X11 attendibili sfruttando problemi di configurazione su tale server X11, come dimostrato dalla mancanza dell'estensione SECURITY su questo server.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per ottenere accesso non autorizzato a sessioni X11 e aggirare restrizioni di sicurezza legate al forwarding grafico .
Soluzione:	Aggiornare Apache HTTP Server a una versione successiva alla 2.4.54 ($\geq 2.4.55$) e disabilitare <code>mod_proxy_ajp</code> se non necessario.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2016-1908 https://www.cvedetails.com/cve/CVE-2016-1908/

Identificativo/ Livello:	CVE-2023-38408/ CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	La funzionalità PKCS#11 in ssh-agent in OpenSSH prima della versione 9.3p2 presenta un percorso di ricerca non sufficientemente affidabile, che può portare all'esecuzione di codice remoto se un agente viene inoltrato a un sistema controllato da un utente malintenzionato. (Il codice in <code>/usr/lib</code> non è necessariamente sicuro per il caricamento in ssh-agent.) NOTA: questo problema esiste a causa di una correzione incompleta per CVE-2016-10009.
Impatto:	Un attaccante remoto può eseguire codice arbitrario sul sistema dell'utente, compromettere completamente la workstation della vittima e accedere a chiavi SSH, repository e altre sessioni attive.
Soluzione:	Aggiornare OpenSSH alla versione 9.3p2 o successiva.
Detection:	Analisi manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2023-38408 https://www.cvedetails.com/cve/CVE-2023-38408/

Identificativo/ Livello:	CVE - / CVSS v3.0/v3.1: 10/10 (Critical)
Descrizione:	In base alla sua versione, Debian Linux è la 8.x. Pertanto, non è più supportata dal suo fornitore. La mancanza di supporto implica che il fornitore non rilascerà nuove patch di sicurezza per il prodotto. Di conseguenza, potrebbe presentare vulnerabilità di sicurezza.
Impatto:	Il sistema non ricevendo più aggiornamenti di sicurezza risulta esposto a vulnerabilità note e future, aumentando significativamente il rischio di compromissione della riservatezza, integrità e disponibilità dei servizi ospitati.
Soluzione:	Esegui l'aggiornamento a una versione di Debian Linux attualmente supportata.
Detection:	Nessus
Riferimenti:	Report Nessus

Identificativo/ Livello:	CVE-2016-10033 / CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	La funzione <code>mailSend</code> nel trasporto <code>isMail</code> di PHPMailer, nelle versioni precedenti alla 5.2.18, potrebbe consentire ad aggressori remoti di passare parametri aggiuntivi al comando <code>mail</code> e di conseguenza eseguire codice arbitrario tramite un <code>'</code> (virgoletta doppia barra rovesciata) in una proprietà <code>Sender</code> appositamente creata.
Impatto:	Un attaccante può sfruttarla per eseguire comandi sul server tramite l'invio di email malevoli, compromettendo quindi riservatezza, integrità e disponibilità del sistema.
Soluzione:	Aggiornare PHPMailer a una versione successiva alla 5.2.18 e verificare che l'input usato per l'invio delle email sia correttamente validato.
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2016-10033 https://www.cve.org/CVERecord?id=CVE-2016-10033

Identificativo/ Livello:	CVE-2018-20148 / CVSS v3.0/v3.1: 9.8/10 (Critical)
Descrizione:	Nelle versioni di WordPress precedenti alla 4.9.9 e nelle versioni 5.x precedenti alla 5.0.1, i collaboratori potevano effettuare attacchi di iniezione di oggetti PHP tramite metadati

	appositamente creati in una chiamata XMLRPC wp.getMediaItem. Ciò era causato da una gestione errata dei dati serializzati negli URL phar:// nella funzione wp_get_attachment_thumb_file in wp-includes/post.php.
Impatto:	Un attaccante può compromettere il sito WordPress arrivando potenzialmente a eseguire codice sul server, con impatto totale su riservatezza, integrità e disponibilità.
Soluzione:	Aggiornare WordPress alla versione 5.0.1 o successiva e disabilitare o limitare funzionalità che processano input serializzati non fidati.
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2018-20148 https://www.cve.org/CVERecord?id=CVE-2018-20148

6.2 VULNERABILITÀ CLASSIFICATE: ALTE

Le vulnerabilità classificate **HIGH** sono:

Identificativo/ Livello:	CVE-2018-20151 / CVSS v3.0/v3.1: 7.5/10 (High)
Descrizione:	Nelle versioni di WordPress precedenti alla 4.9.9 e nelle versioni 5.x precedenti alla 5.0.1, la pagina di attivazione utente poteva essere letta dal crawler di un motore di ricerca se veniva scelta una configurazione insolita. Il motore di ricerca poteva quindi indicizzare e visualizzare l'indirizzo e-mail dell'utente e (raramente) la password generata di default.
Impatto:	Un attaccante non interagendo direttamente con il sistema può ottenere informazioni sensibili degli utenti (data leak), compromettendo principalmente la riservatezza.
Soluzione:	Aggiornare WordPress alla versione 4.9.9 o 5.0.1 o successive.
Detection:	Analisi Manuale
Riferimenti:	https://www.cve.org/CVERecord?id=CVE-2018-20151 https://nvd.nist.gov/vuln/detail/CVE-2018-20151

Identificativo/ Livello:	CVE-2015-5600 / CVSS v3.0/v3.1: 7.5/10 (High)
Descrizione:	La funzione kbdint_next_device in auth2-chall.c in sshd in OpenSSH fino alla versione 6.9 non limita correttamente l'elaborazione dei dispositivi interattivi con tastiera all'interno di una singola connessione, il che facilita agli aggressori remoti l'esecuzione di attacchi di forza bruta o la causazione di un denial of service (consumo eccessivo di CPU) tramite un elenco lungo e duplicato nell'opzione ssh -oKbdInteractiveDevices, come dimostrato da un client modificato che fornisce una password diversa per ogni elemento pam in questo elenco.
Impatto:	Può portare a un Denial of Service (DoS), rendendo il servizio SSH lento o non disponibile e degradando le prestazioni del server.
Soluzione:	Aggiornare OpenSSH a una versione superiore e applicare limitazioni sulle connessioni SSH per ridurre il rischio di consumo eccessivo di risorse.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2015-5600/ https://nvd.nist.gov/vuln/detail/CVE-2015-5600

Identificativo/ Livello:	CVE-2016-35385 / CVSS v3.0/v3.1: 8.1/10 (High)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 10.3, un file scaricato tramite scp poteva essere installato con setuid o setgid, un risultato contrario alle aspettative di alcuni utenti, se il download veniva eseguito come root con -O (protocollo scp legacy) e senza -p (modalità di conservazione).
Impatto:	Possibile escalation di privilegi e creazione di file con permessi root non sicuri.
Soluzione:	Aggiornare OpenSSH alla versione 10.3+ e usare sftp invece di scp legacy.
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2016-35385 https://www.cvedetails.com/cve/CVE-2016-35385/

Identificativo/ Livello:	CVE-2016-0778 / CVSS v3.0/v3.1: 8.1/10 (High)
Descrizione:	Le funzioni (1) roaming_read e (2) roaming_write in roaming_common.c nel client di

	OpenSSH 5.x, 6.x e 7.x precedenti alla 7.1p2, quando sono abilitate determinate opzioni proxy e di inoltro, non mantengono correttamente i descrittori del file di connessione, il che consente ai server remoti di causare un denial of service (overflow del buffer basato sull'heap) o potenzialmente avere altri impatti non specificati richiedendo molti inoltri.
Impatto:	Un attaccante remoto può sfruttarla per causare un Denial of Service (crash del client SSH) e, in alcuni scenari, potenzialmente eseguire codice arbitrario, compromettendo la stabilità e la sicurezza della sessione SSH.
Soluzione:	Aggiornare OpenSSH alla versione 7.1p2 o successiva, che rimuove la funzionalità roaming e corregge la gestione della memoria nelle connessioni.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-0778/ https://nvd.nist.gov/vuln/detail/CVE-2016-0778

Identificativo/ Livello:	CVE-2026-35386 / CVSS v3.0/v3.1: 8.1/10 (High)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 10.3, l'esecuzione dei comandi poteva avvenire tramite metacaratteri della shell presenti nel nome utente all'interno di una riga di comando. Ciò richiedeva uno scenario in cui il nome utente sulla riga di comando non fosse considerato attendibile e una configurazione non predefinita del parametro % in ssh_config.
Impatto:	Possibile esecuzione di codice remoto (RCE) e compromissione del sistema in condizioni specifiche.
Soluzione:	Aggiornare OpenSSH alla versione 10.3 o superiore e evitare configurazioni non standard che elaborano username non fidati.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-35386/ https://nvd.nist.gov/vuln/detail/CVE-2026-35386

Identificativo/ Livello:	CVE-2026-35414 / CVSS v3.0/v3.1: 8.1/10 (High)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 10.3, l'opzione `authorized_keys` relativa ai principal non viene gestita correttamente in scenari non comuni che coinvolgono un elenco di principal in combinazione con un'Autorità di Certificazione che utilizza determinati caratteri virgola.
Impatto:	Possibile bypass dei controlli di autenticazione SSH e accesso non autorizzato.
Soluzione:	Aggiornare OpenSSH alla versione 10.3 o superiore e verificare la corretta configurazione delle chiavi/certificati SSH.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-35414/ https://nvd.nist.gov/vuln/detail/CVE-2026-35414

Identificativo/ Livello:	CVE-2026-10012 / CVSS v3.0/v3.1: 7.8/10 (High)
Descrizione:	Il gestore della memoria condivisa (associato alla compressione pre-autenticazione) in sshd in OpenSSH prima della versione 7.4 non garantisce che un controllo dei limiti venga applicato da tutti i compilatori, il che potrebbe consentire agli utenti locali di ottenere privilegi sfruttando l'accesso a un processo di separazione dei privilegi in ambiente sandbox, correlato alle strutture dati m_zback e m_zlib.
Impatto:	Possibile escalation di privilegi locali se un attaccante compromette il processo di separazione dei privilegi.
Soluzione:	Aggiornare OpenSSH alla versione 7.4 o superiore e applicare le patch di sicurezza disponibili.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-10012/ https://nvd.nist.gov/vuln/detail/CVE-2016-10012

Identificativo/ Livello:	CVE-2020-15778 / CVSS v3.0/v3.1: 7.4/10 (High)
Descrizione:	scp in OpenSSH fino alla versione 8.3p1 consente l'iniezione di comandi nella funzione toremote di scp.c, come dimostrato dai caratteri backtick nell'argomento destination.

	NOTA: il fornitore avrebbe dichiarato di omettere intenzionalmente la convalida dei "trasferimenti di argomenti anomali" perché ciò potrebbe "compromettere seriamente i flussi di lavoro esistenti".
Impatto:	Possibile esecuzione di comandi arbitrari sul sistema durante trasferimenti SCP.
Soluzione:	Aggiornare OpenSSH oltre la versione 8.3p1 e preferire strumenti più sicuri come sftp o alternative a SCP legacy.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2020-15778/ https://nvd.nist.gov/vuln/detail/CVE-2020-15778
Identificativo/ Livello:	CVE-2016-10009 / CVSS v3.0/v3.1: 7.3/10 (High)
Descrizione:	Una vulnerabilità di percorso di ricerca non attendibile in ssh-agent.c in ssh-agent in OpenSSH prima della versione 7.4 consente ad aggressori remoti di eseguire moduli PKCS#11 locali arbitrari sfruttando il controllo su un agent-socket inoltrato.
Impatto:	Possibile esecuzione di codice locale arbitrario tramite manipolazione di moduli PKCS#11.
Soluzione:	Aggiornare OpenSSH alla versione 7.4 o superiore e limitare o disabilitare l'uso di ssh-agent forwarding se non necessario.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-10009/ https://nvd.nist.gov/vuln/detail/CVE-2016-10009
Identificativo/ Livello:	CVE-2016-10708 / CVSS v3.0/v3.1: 7.5/10 (High)
Descrizione:	sshd in OpenSSH prima della 7.4 consente agli aggressori remoti di causare una negazione del servizio (dereferenza del puntatore NULL e arresto anomalo del demone) tramite un messaggio NEWKEYS fuori sequenza, come dimostrato da Honggfuzz, relativo a kex.c e packet.c.
Impatto:	Possibile Denial of Service (DoS) con interruzione del servizio SSH.
Soluzione:	Aggiornare OpenSSH alla versione 7.4 o superiore.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-10708/ https://nvd.nist.gov/vuln/detail/CVE-2016-10708
Identificativo/ Livello:	CVE-2016-10010 / CVSS v3.0/v3.1: 7.0/10 (High)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 7.4, quando non veniva utilizzata la separazione dei privilegi, sshd creava socket di dominio Unix inoltrati come root, il che poteva consentire agli utenti locali di ottenere privilegi tramite vettori non specificati, correlati a serverloop.c.
Impatto:	Possibile escalation di privilegi locali fino a root in configurazioni specifiche.
Soluzione:	Aggiornare OpenSSH alla versione 7.4 o superiore e mantenere attivo il privilege separation
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-10010/ https://nvd.nist.gov/vuln/detail/CVE-2016-10010
Identificativo/ Livello:	CVE-2021-41617 / CVSS v3.0/v3.1: 7.0/10 (High)
Descrizione:	Nelle versioni di OpenSSH dalla 6.2 alla 8.x precedenti alla 8.8, il comando sshd, quando si utilizzano determinate configurazioni non predefinite, consente l'escalation dei privilegi poiché i gruppi supplementari non vengono inizializzati come previsto. I programmi di supporto per AuthorizedKeysCommand e AuthorizedPrincipalsCommand possono essere eseguiti con privilegi associati all'appartenenza ai gruppi del processo sshd, se la configurazione specifica l'esecuzione del comando come un utente diverso.
Impatto:	Possibile escalation di privilegi locali fino a livello root in specifiche configurazioni.
Soluzione:	Aggiornare OpenSSH alla versione 8.8 o superiore e disabilitare o limitare l'uso di AuthorizedKeysCommand e AuthorizedPrincipalsCommand se non necessari.

Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2021-41617/ https://nvd.nist.gov/vuln/detail/CVE-2021-41617

Identificativo/ Livello:	CGI Generic SSI Injection (HTTP headers) CWE-97 -96-94- 74-727-632-75-752- 713// CVSS v2.0: 7.5/10 (High)
Descrizione:	Il server web remoto ospita uno o più script CGI che non sanificano adeguatamente le stringhe di richiesta e sembrano essere vulnerabili a un attacco di 'iniezione SSI'. Sfruttando questa vulnerabilità, un utente malintenzionato potrebbe essere in grado di eseguire comandi arbitrari sull'host remoto.
Impatto:	La vulnerabilità consente a un attaccante remoto di sfruttare un'iniezione SSI per eseguire comandi arbitrari sul server, portando potenzialmente alla compromissione completa del sistema e alla perdita di riservatezza, integrità e disponibilità.
Soluzione:	Disabilita le Server Side Includes se non le utilizzi, altrimenti limita l'accesso all'applicazione vulnerabile o contatta il fornitore per una patch/un aggiornamento.
Detection:	Nessus
Riferimenti:	https://cwe.mitre.org/data/definitions/97.html https://cwe.mitre.org/data/definitions/74.html https://cwe.mitre.org/data/definitions/96.html https://cwe.mitre.org/data/definitions/727.html https://cwe.mitre.org/data/definitions/94.html https://cwe.mitre.org/data/definitions/632.html https://cwe.mitre.org/data/definitions/75.html https://cwe.mitre.org/data/definitions/752.html https://cwe.mitre.org/data/definitions/713.html

Identificativo/ Livello:	CVE-2026-24072 / CVSS v3.1: 8.8 / 10 (High)
Descrizione:	Un bug di escalation dei privilegi presente in diversi moduli di Apache HTTP 2.4.66 e versioni precedenti consente agli autori locali di file .htaccess di leggere i file con i privilegi dell'utente httpd. Si consiglia agli utenti di aggiornare alla versione 2.4.67, che risolve questo problema.
Impatto:	La vulnerabilità consente a un utente locale con accesso a .htaccess di leggere file con i privilegi del processo Apache, causando privilege escalation.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.67 o superiore per correggere la gestione dei privilegi.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-24072/ https://nvd.nist.gov/vuln/detail/CVE-2026-24072

Identificativo/ Livello:	CVE-2025-58098 / CVSS v3.1: 8.3 / 10 (High)
Descrizione:	Apache HTTP Server 2.4.65 e versioni precedenti con Server Side Includes (SSI) abilitato e mod_cgid (ma non mod_cgi) passa la stringa di query con escape shell alle direttive #exec cmd="...". Questo problema interessa Apache HTTP Server prima della versione 2.4.66. Si consiglia agli utenti di aggiornare alla versione 2.4.66, che risolve il problema.
Impatto:	La vulnerabilità consente a un attaccante remoto di manipolare la gestione delle query string nei Server Side Includes, con possibile esposizione di informazioni sensibili o alterazione del comportamento del server.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.66 o superiore per correggere la gestione sicura delle query string in SSI.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2025-58098/ https://nvd.nist.gov/vuln/detail/CVE-2025-58098

Identificativo/ Livello:	CVE-2016-5387 / CVSS v3.1: 8.1 / 10 (High)
Descrizione:	Il server HTTP Apache fino alla versione 2.4.23 è conforme alla sezione 4.1.18 della RFC 3875 e pertanto non protegge le applicazioni dalla presenza di dati client non attendibili nella variabile d'ambiente HTTP_PROXY, che potrebbe consentire ad aggressori remoti di reindirizzare il traffico HTTP in uscita di un'applicazione verso un server proxy arbitrario tramite un'intestazione Proxy appositamente creata in una richiesta HTTP, ovvero un problema "httpoxy". NOTA: il fornitore dichiara che "A questa mitigazione è stato

	assegnato l'identificativo CVE-2016-5387"; in altre parole, questo non è un ID CVE per una vulnerabilità.
Impatto:	La vulnerabilità consente a un attaccante remoto di manipolare le connessioni HTTP in uscita del server tramite injection dell'header Proxy (httproxy).
Soluzione:	Aggiornare Apache HTTP Server oltre la versione 2.4.23 e applicare le patch che proteggono la variabile HTTP_PROXY.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-5387/ https://nvd.nist.gov/vuln/detail/CVE-2016-5387

Identificativo/ Livello:	CVE-2017-15715 / CVSS v3.1: 8.1 / 10 (High)
Descrizione:	Nelle versioni di Apache httpd dalla 2.4.0 alla 2.4.29, l'espressione specificata in <FilesMatch> poteva far corrispondere il carattere '\$' a un carattere di nuova riga in un nome file dannoso, anziché corrispondere solo alla parte finale del nome file. Questa vulnerabilità poteva essere sfruttata in ambienti in cui il caricamento di alcuni file è bloccato esternamente, ma solo tramite la corrispondenza con la parte finale del nome file.
Impatto:	La vulnerabilità consente a un attaccante remoto di bypassare i controlli sui nomi dei file upload sfruttando il trattamento errato del carattere newline nelle espressioni FilesMatch.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.33 o superiore per correggere il pattern matching nei filtri FilesMatch.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2017-15715/ https://nvd.nist.gov/vuln/detail/CVE-2017-15715

Identificativo/ Livello:	CVE-2024-38473 / CVSS v3.1: 8.1 / 10 (High)
Descrizione:	Un problema di codifica in mod_proxy nelle versioni 2.4.59 e precedenti di Apache HTTP Server consente l'invio di URL di richiesta con codifica errata ai servizi di backend, potenzialmente aggirando l'autenticazione tramite richieste appositamente create. Si consiglia agli utenti di aggiornare alla versione 2.4.60, che risolve questo problema.
Impatto:	La vulnerabilità consente a un attaccante remoto di bypassare l'autenticazione verso i servizi backend tramite richieste HTTP con encoding non corretta
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.60 o superiore per correggere la gestione dell'encoding nel modulo mod_proxy.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-38473/ https://nvd.nist.gov/vuln/detail/CVE-2024-38473

Identificativo/ Livello:	CVE-2006-20001 / CVSS v3.1: 7.5 / 10 (High)
Descrizione:	Un'intestazione di richiesta If: attentamente progettata può causare la lettura o la scrittura di un singolo byte zero in una posizione di memoria del pool (heap) al di fuori del valore dell'intestazione inviata. Ciò potrebbe causare l'arresto anomalo del processo. Questo problema riguarda Apache HTTP Server 2.4.54 e versioni precedenti.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache o alterare la memoria tramite un header HTTP If manipolato.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.55 o superiore per correggere la gestione della memoria nell'elaborazione dell'header If.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2006-20001/ https://nvd.nist.gov/vuln/detail/CVE-2006-20001

Identificativo/ Livello:	CVE-2016-0736/ CVSS v3.1: 7.5 / 10 (High)
Descrizione:	Nelle versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.23, il modulo mod_session_crypto crittografava i dati/cookie utilizzando gli algoritmi di cifratura configurati, potenzialmente con modalità operative CBC o ECB (AES256-CBC per impostazione predefinita), pertanto non era disponibile alcuna crittografia autenticata selezionabile o integrata. Ciò lo rendeva vulnerabile agli attacchi di padding oracle, in particolare con CBC.

Impatto:	La vulnerabilità consente a un attaccante remoto di eseguire un padding oracle attack e decifrare dati sensibili delle sessioni Apache.
Soluzione:	Aggiornare Apache HTTP Server oltre la versione 2.4.23 per correggere l'uso insicuro della crittografia nel modulo <code>mod_session_crypto</code> .
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-0736/ https://nvd.nist.gov/vuln/detail/CVE-2016-0736

Identificativo/ Livello:	CVE-2016-2161 / CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Nelle versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.23, l'inserimento di dati dannosi nel modulo <code>mod_auth_digest</code> può causare il blocco del server, e ogni istanza continua a bloccarsi anche per le richieste successive valide.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per causare un Denial of Service (DoS) persistente del servizio web, rendendo il server non disponibile e interrompendo l'accesso agli utenti legittimi.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.24 o superiore per correggere il problema nel modulo <code>mod_auth_digest</code> .
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-2161/ https://nvd.nist.gov/vuln/detail/CVE-2016-2161

Identificativo/ Livello:	CVE-2016-8743 / CVSS v3.1: 7.5 / 10 (High)
Descrizione:	Il server HTTP Apache, in tutte le versioni precedenti alla 2.2.32 e alla 2.4.25, era permissivo nella gestione degli spazi bianchi accettati nelle richieste e inviati nelle righe e nelle intestazioni delle risposte. Accettare questi comportamenti diversi rappresentava un problema di sicurezza quando <code>httpd</code> partecipava a una catena di proxy o interagiva con server applicativi back-end, sia tramite <code>mod_proxy</code> che utilizzando meccanismi CGI convenzionali, e poteva comportare il "request smuggling", la suddivisione delle risposte e l'inquinamento della cache.
Impatto:	La vulnerabilità consente a un attaccante remoto di manipolare richieste HTTP tramite whitespace non standard, causando request smuggling e cache poisoning.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.25 o superiore per correggere la gestione dei caratteri whitespace nelle richieste HTTP.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-8743/ https://nvd.nist.gov/vuln/detail/CVE-2016-8743

Identificativo/ Livello:	CVE-2017-9798 / CVSS v3.1: 7.5 / 10 (High)
Descrizione:	Apache <code>httpd</code> consente agli aggressori remoti di leggere dati riservati dalla memoria di processo se la direttiva <code>Limit</code> è impostata nel file <code>.htaccess</code> dell'utente o se <code>httpd.conf</code> presenta determinate configurazioni errate, note anche come <code>Optionsbleed</code> . Questo problema interessa Apache HTTP Server fino alla versione 2.2.34 e dalla 2.4.x alla 2.4.27. L'aggressore invia una richiesta HTTP <code>OPTIONS</code> non autenticata quando tenta di leggere i dati riservati. Si tratta di un problema di tipo use-after-free, pertanto i dati riservati non vengono sempre inviati e i dati specifici dipendono da molti fattori, inclusa la configurazione. Lo sfruttamento tramite <code>.htaccess</code> può essere bloccato con una patch alla funzione <code>ap_limit_section</code> in <code>server/core.c</code> .
Impatto:	La vulnerabilità consente a un attaccante remoto di leggere porzioni della memoria del processo Apache tramite richieste <code>OPTIONS</code> malevole (<code>Optionsbleed</code>).
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.28 o superiore per correggere il use-after-free nella gestione della direttiva <code>Limit</code> .
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2017-9798/ https://nvd.nist.gov/vuln/detail/CVE-2017-9798

Identificativo/ Livello:	CVE-2017-15710 / CVSS v3.0: 7.5 / 10 (High)
--------------------------	---

Descrizione:	Nelle versioni di Apache httpd dalla 2.0.23 alla 2.0.65, dalla 2.2.0 alla 2.2.34 e dalla 2.4.0 alla 2.4.29, il modulo mod_authnz_ldap, se configurato con AuthLDAPCharsetConfig, utilizza il valore dell'intestazione Accept-Language per cercare la codifica del set di caratteri corretta durante la verifica delle credenziali dell'utente. Se il valore dell'intestazione non è presente nella tabella di conversione del set di caratteri, viene utilizzato un meccanismo di fallback per troncarlo a un valore di due caratteri, consentendo un rapido tentativo di ripetizione (ad esempio, 'en-US' viene troncato a 'en'). Un valore dell'intestazione inferiore a due caratteri forza una scrittura fuori dai limiti di un byte NUL in una posizione di memoria non facente parte della stringa. Nel peggiore dei casi, piuttosto improbabile, il processo andrebbe in crash, il che potrebbe essere sfruttato per un attacco Denial of Service. Nel caso più probabile, questa memoria è già riservata per usi futuri e il problema non ha alcun effetto.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache o una scrittura fuori dai limiti di memoria tramite un header Accept-Language manipolato.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.30 o superiore per correggere la gestione dell'header Accept-Language nel modulo mod_authnz_ldap.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2017-15710/ https://nvd.nist.gov/vuln/detail/CVE-2017-15710

Identificativo/ Livello:	CVE-2018-1303/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Un'intestazione di richiesta HTTP appositamente creata avrebbe potuto causare il crash del server HTTP Apache prima della versione 2.4.30 a causa di una lettura fuori dai limiti durante la preparazione dei dati da memorizzare nella cache condivisa. Questa vulnerabilità poteva essere sfruttata per un attacco Denial of Service (DoS) contro gli utenti di mod_cache_socache. La vulnerabilità è considerata a basso rischio poiché mod_cache_socache non è ampiamente utilizzato e mod_cache_disk non è interessato da questa vulnerabilità.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache tramite un out-of-bounds read nel modulo mod_cache_socache.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.30 o superiore per correggere la gestione della cache condivisa.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2018-1303/ https://nvd.nist.gov/vuln/detail/CVE-2018-1303

Identificativo/ Livello:	CVE-2018-17199/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Nelle versioni di Apache HTTP Server 2.4, versione 2.4.37 e precedenti, mod_session verifica il tempo di scadenza della sessione prima di decodificarla. Questo fa sì che il tempo di scadenza della sessione venga ignorato per le sessioni mod_session_cookie, poiché viene caricato al momento della decodifica della sessione.
Impatto:	La vulnerabilità consente a un attaccante remoto di bypassare la scadenza delle sessioni in Apache mod_session, mantenendo sessioni valide oltre il tempo previsto.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.38 o superiore per correggere la gestione della scadenza delle sessioni.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2018-17199/ https://nvd.nist.gov/vuln/detail/CVE-2018-17199

Identificativo/ Livello:	CVE-2019-0217/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Nelle versioni di Apache HTTP Server 2.4, 2.4.38 e precedenti, una condizione di competizione (race condition) nel modulo mod_auth_digest, quando eseguito in un server multi-thread, poteva consentire a un utente con credenziali valide di autenticarsi utilizzando un altro nome utente, aggirando le restrizioni di controllo degli accessi configurate.
Impatto:	La vulnerabilità consente a un attaccante autenticato di effettuare un bypass dell'autenticazione in Apache mod_auth_digest sfruttando una race condition.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.39 o superiore per correggere la

	gestione concorrente dell'autenticazione Digest.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2019-0217/ https://nvd.nist.gov/vuln/detail/CVE-2019-0217

Identificativo/ Livello:	CVE-2021-26690/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Nelle versioni del server HTTP Apache dalla 2.4.0 alla 2.4.46, un'intestazione Cookie appositamente creata e gestita da mod_session può causare un dereferenzamento di puntatore NULL e un arresto anomalo, con conseguente possibile Denial of Service.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache tramite un Cookie manipolato che provoca una NULL pointer dereference.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.47 o superiore per correggere la gestione delle sessioni nel modulo mod_session.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2021-26690/ https://nvd.nist.gov/vuln/detail/CVE-2021-26690

Identificativo/ Livello:	CVE-2021-34798/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Le richieste non valide possono causare la dereferenziazione di un puntatore NULL da parte del server. Questo problema riguarda Apache HTTP Server 2.4.48 e versioni precedenti.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache tramite richieste HTTP malformate che provocano una NULL pointer dereference.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.49 o superiore per correggere la gestione delle richieste HTTP malformate.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2021-34798/ https://nvd.nist.gov/vuln/detail/CVE-2021-34798

Identificativo/ Livello:	CVE-2022-22719/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Un corpo della richiesta attentamente progettato può causare la lettura di un'area di memoria casuale, con conseguente possibile arresto anomalo del processo. Questo problema interessa Apache HTTP Server 2.4.52 e versioni precedenti.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache tramite richieste HTTP che sfruttano una lettura di memoria non inizializzata nel modulo mod_lua.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.53 o superiore per correggere la gestione della memoria nel modulo mod_lua.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2022-22719/ https://nvd.nist.gov/vuln/detail/CVE-2022-22719

Identificativo/ Livello:	CVE-2022-26377/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	La vulnerabilità di interpretazione incoerente delle richieste HTTP ('HTTP Request Smuggling') presente nel modulo mod_proxy_ajp del server HTTP Apache consente a un utente malintenzionato di instradare le richieste verso il server AJP a cui vengono inoltrate. Questo problema interessa le versioni di Apache HTTP Server 2.4, 2.4.53 e precedenti.
Impatto:	La vulnerabilità consente a un attaccante remoto di effettuare HTTP Request Smuggling tramite il modulo mod_proxy_ajp, bypassando i controlli tra frontend e backend.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.54 o superiore per correggere la gestione delle richieste HTTP nel modulo mod_proxy_ajp.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2022-26377/ https://nvd.nist.gov/vuln/detail/CVE-2022-26377

Identificativo/ Livello:	CVE-2022-29404/ CVSS v3.0: 7.5 / 10 (High)
--------------------------	--

Descrizione:	Nelle versioni di Apache HTTP Server 2.4.53 e precedenti, una richiesta malevola a uno script Lua che chiama <code>r:parsebody(0)</code> può causare un denial of service a causa dell'assenza di un limite predefinito sulla dimensione possibile dell'input.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un Denial of Service sfruttando richieste Lua senza limiti nella dimensione del body.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.54 o superiore per imporre limiti di input nel modulo <code>mod_lua</code> .
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2022-29404 https://www.cvedetails.com/cve/CVE-2022-29404/

Identificativo/ Livello:	CVE-2022-30556/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Apache HTTP Server 2.4.53 e versioni precedenti potrebbero restituire alle applicazioni che chiamano <code>r:wsread()</code> lunghezze che puntano oltre la fine dello spazio di archiviazione allocato per il buffer.
Impatto:	La vulnerabilità consente a un attaccante remoto di leggere dati sensibili dalla memoria del server Apache tramite un out-of-bounds read nel modulo <code>mod_lua</code> WebSocket.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.54 o superiore per correggere la gestione della memoria in <code>r:wsread()</code> .
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2022-30556/ https://nvd.nist.gov/vuln/detail/CVE-2022-30556

Identificativo/ Livello:	CVE-2023-31122/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Vulnerabilità di lettura fuori dai limiti nella macro <code>mod_macro</code> del server HTTP Apache. Questo problema interessa il server HTTP Apache fino alla versione 2.4.57.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache o leggere memoria tramite un out-of-bounds read nel modulo <code>mod_macro</code> .
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.58 o superiore per correggere la gestione delle macro.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2023-31122/ https://nvd.nist.gov/vuln/detail/CVE-2023-31122

Identificativo/ Livello:	CVE-2024-38477/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Una vulnerabilità di dereferenziazione di puntatore nullo in <code>mod_proxy</code> nel server HTTP Apache 2.4.59 e versioni precedenti consente a un utente malintenzionato di mandare in crash il server tramite una richiesta dannosa. Si consiglia agli utenti di aggiornare alla versione 2.4.60, che risolve questo problema.
Impatto:	La vulnerabilità consente a un attaccante remoto di causare un crash del server Apache tramite una null pointer dereference nel modulo <code>mod_proxy</code> .
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.60 o superiore per correggere la gestione delle richieste nel modulo <code>mod_proxy</code> .
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-38477/ https://nvd.nist.gov/vuln/detail/CVE-2024-38477

Identificativo/ Livello:	CVE-2024-39573/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Una potenziale vulnerabilità SSRF in <code>mod_rewrite</code> di Apache HTTP Server 2.4.59 e versioni precedenti consente a un utente malintenzionato di forzare l'impostazione di RewriteRules non sicure per configurare in modo imprevisto gli URL da gestire tramite <code>mod_proxy</code> . Si consiglia agli utenti di aggiornare alla versione 2.4.60, che risolve questo problema.
Impatto:	La vulnerabilità consente a un attaccante remoto di sfruttare <code>mod_rewrite</code> per generare richieste SSRF verso <code>mod_proxy</code> e accedere a risorse interne.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.60 o superiore per correggere la

	gestione delle RewriteRule.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-39573/ https://nvd.nist.gov/vuln/detail/CVE-2024-39573

Identificativo/ Livello:	CVE-2024-42516/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	La funzionalità di suddivisione della risposta HTTP nel core di Apache HTTP Server consente a un utente malintenzionato in grado di manipolare le intestazioni di risposta Content-Type delle applicazioni ospitate o utilizzate come proxy dal server di suddividere la risposta HTTP. Questa vulnerabilità è stata identificata come CVE-2023-38709, ma la patch inclusa in Apache HTTP Server 2.4.59 non ha risolto il problema. Si consiglia agli utenti di aggiornare alla versione 2.4.64, che corregge questa vulnerabilità.
Impatto:	La vulnerabilità consente a un attaccante remoto di manipolare l'header Content-Type causando HTTP response splitting e possibili attacchi di cache poisoning o XSS.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.64 o superiore per correggere la gestione delle risposte HTTP.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-42516/ https://nvd.nist.gov/vuln/detail/CVE-2024-42516

Identificativo/ Livello:	CVE-2024-43204/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Una vulnerabilità SSRF nel server HTTP Apache con mod_proxy caricato consente a un utente malintenzionato di inviare richieste proxy in uscita a un URL controllato dall'attaccante stesso. Ciò richiede una configurazione insolita in cui mod_headers è configurato per modificare l'intestazione Content-Type della richiesta o della risposta con un valore fornito nella richiesta HTTP.
Impatto:	La vulnerabilità consente a un attaccante remoto di forzare Apache a effettuare richieste SSRF verso host controllati tramite una configurazione errata di mod_proxy e mod_headers.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.64 o superiore per correggere la gestione degli header e prevenire richieste non autorizzate.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-43204/ https://nvd.nist.gov/vuln/detail/CVE-2024-43204

Identificativo/ Livello:	CVE-2024-43394/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	La vulnerabilità Server-Side Request Forgery (SSRF) nel server HTTP Apache su Windows consente potenzialmente la divulgazione di hash NTLM a un server malevolo tramite mod_rewrite o espressioni Apache che trasmettono input di richiesta non validati. Questo problema interessa le versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.63. Nota: il progetto Apache HTTP Server adotterà criteri più rigorosi per l'accettazione di segnalazioni di vulnerabilità relative a SSRF tramite percorsi UNC. Il server offre una protezione limitata contro gli amministratori che configurano percorsi UNC aperti. I server Windows dovrebbero limitare gli host a cui si connettono tramite SMB in base alla natura dell'autenticazione NTLM.
Impatto:	Possibile esfiltrazione di credenziali NTLM e compromissione della sicurezza delle comunicazioni su sistemi Windows, con esposizione di informazioni sensibili verso attaccanti remoti.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.64 o superiore e limitare le connessioni SMB/UNC non necessarie nei sistemi Windows per ridurre il rischio di sfruttamento.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-43394/ https://nvd.nist.gov/vuln/detail/CVE-2024-43394

Identificativo/ Livello:	CVE-2024-47252/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	La gestione insufficiente dei caratteri di escape per i dati forniti dall'utente in mod_ssl nelle versioni 2.4.63 e precedenti di Apache HTTP Server consente a un client SSL/TLS non attendibile di inserire caratteri di escape nei file di log in alcune configurazioni. In una

	configurazione di logging in cui CustomLog viene utilizzato con "%{varname}x" o "%{varname}c" per registrare variabili fornite da mod_ssl come SSL_TLS_SNI, né mod_log_config né mod_ssl eseguono alcuna operazione di escape e i dati non sanificati forniti dal client potrebbero comparire nei file di log.
Impatto:	Possibile manipolazione o inquinamento dei file di log, con rischio di occultamento o alterazione delle informazioni registrate e impatto sulla tracciabilità degli eventi di sicurezza.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.64 o successiva e verificare la corretta configurazione del logging per garantire l'escaping dei dati inseriti nei log.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-47252/ https://nvd.nist.gov/vuln/detail/CVE-2024-47252

Identificativo/ Livello:	CVE-2026-29169 / CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Un errore di dereferenziazione di puntatore NULL in mod_dav_lock in Apache HTTP Server 2.4.66 e versioni precedenti potrebbe consentire a un utente malintenzionato di mandare in crash il server con una richiesta dannosa. mod_dav_lock non viene utilizzato internamente da mod_dav o mod_dav_fs. L'unico caso d'uso noto per mod_dav_lock era mod_dav_svn di Apache Subversion precedente alla versione 1.2.0. Si consiglia agli utenti di aggiornare alla versione 2.4.66, che risolve questo problema, oppure di rimuovere mod_dav_lock.
Impatto:	Possibile crash del servizio HTTP con conseguente interruzione della disponibilità del server.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.67 o successiva oppure rimuovere il modulo mod_dav_lock se non necessario.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-29169/ https://nvd.nist.gov/vuln/detail/CVE-2026-29169

Identificativo/ Livello:	CVE-2026-34059/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Vulnerabilità di tipo Buffer Overread nel server HTTP Apache. Questo problema interessa le versioni di Apache HTTP Server fino alla 2.4.66.
Impatto:	Possibile esposizione di informazioni sensibili dalla memoria del server, con rischio di data leak e riduzione della confidenzialità del sistema.
Soluzione:	Si consiglia agli utenti di aggiornare alla versione 2.4.67, che risolve il problema.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-34059/ https://nvd.nist.gov/vuln/detail/CVE-2026-34059

Identificativo/ Livello:	CVE-2026-34356/ CVSS v3.0: 7.5 / 10 (High)
Descrizione:	Vulnerabilità di buffer overflow basata su heap nel server HTTP Apache con server backend dannosi e ProxyPassReverseCookie*. Questo problema interessa le versioni del server HTTP Apache dalla 2.4.0 alla 2.4.67.
Impatto:	Possibile crash del servizio o esecuzione di comportamento non previsto dovuto a corruzione della memoria, con conseguente riduzione della disponibilità del server.
Soluzione:	Si consiglia agli utenti di aggiornare alla versione 2.4.68, che risolve il problema.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-34356/ https://nvd.nist.gov/vuln/detail/CVE-2026-34356

Identificativo/ Livello:	CVE-2020-35452/ CVSS v3.0: 7.3 / 10 (High)
Descrizione:	Nelle versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.46, un nonce digest appositamente creato può causare un overflow dello stack in mod_auth_digest. Non ci sono segnalazioni di sfruttamento di questo overflow, né il team di Apache HTTP Server è stato in grado di crearne uno, sebbene alcuni compilatori e/o opzioni di compilazione particolari potrebbero renderlo possibile, con conseguenze comunque limitate a causa delle dimensioni (un singolo byte) e del valore (zero byte) dell'overflow.

Impatto:	Possibile crash del servizio HTTP o comportamento instabile del server, con impatto principalmente sulla disponibilità.
Soluzione:	Aggiornare Apache HTTP Server a una versione successiva alla 2.4.46 che include la patch della vulnerabilità.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2020-35452/ https://nvd.nist.gov/vuln/detail/CVE-2020-35452

Identificativo/ Livello:	CVE-2023-38709/ CVSS v3.0: 7.3 / 10 (High)
Descrizione:	Un errore nella convalida degli input nel core di Apache consente a backend/generatori di contenuti dannosi o sfruttabili di suddividere le risposte HTTP. Questo problema riguarda Apache HTTP Server fino alla versione 2.4.58.
Impatto:	Possibile manipolazione delle risposte HTTP con effetti su integrità e contenuto delle comunicazioni, fino a consentire attacchi di tipo injection o alterazione della risposta del server.
Soluzione:	Aggiornare Apache HTTP Server a una versione successiva alla 2.4.58 che corregge la validazione degli input e previene la manipolazione delle risposte HTTP.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2023-38709/ https://nvd.nist.gov/vuln/detail/CVE-2023-38709

Identificativo/ Livello:	CVE-2026-44185/ CVSS v3.0: 7.3 / 10 (High)
Descrizione:	Vulnerabilità di buffer overread nel server HTTP Apache tramite richieste OCSP in uscita verso un server OCSP controllato da un utente malintenzionato. Questo problema interessa le versioni del server HTTP Apache dalla 2.4.0 alla 2.4.67.
Impatto:	Possibile esposizione di informazioni sensibili dalla memoria del server e degrado della sicurezza del sistema, con impatto su confidenzialità e integrità.
Soluzione:	Si consiglia agli utenti di aggiornare alla versione 2.4.68, che risolve il problema.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-44185/ https://nvd.nist.gov/vuln/detail/CVE-2026-44185

Identificativo/ Livello:	CVE-2026-44185/ CVSS v3.0: 7.3 / 10 (High)
Descrizione:	Vulnerabilità di buffer overread nel server HTTP Apache tramite richieste OCSP in uscita verso un server OCSP controllato da un utente malintenzionato. Questo problema interessa le versioni del server HTTP Apache dalla 2.4.0 alla 2.4.67.
Impatto:	Possibile esposizione di informazioni sensibili dalla memoria del server e degrado della sicurezza del sistema, con impatto su confidenzialità e integrità.
Soluzione:	Si consiglia agli utenti di aggiornare alla versione 2.4.68, che risolve il problema.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-44185/ https://nvd.nist.gov/vuln/detail/CVE-2026-44185

6.3 VULNERABILITÀ CLASSIFICATE: MEDIUM

Le vulnerabilità classificate **MEDIUM** sono:

Identificativo/ Livello:	CVE-2019-6109 / CVSS v3.0/v3.1: 6.8/10 (Medium)
Descrizione:	È stato scoperto un problema in OpenSSH 7.9. A causa della mancanza di codifica dei caratteri nella visualizzazione dell'avanzamento, un server malevolo (o un attaccante Man-in-the-Middle) può utilizzare nomi di oggetti appositamente creati per manipolare l'output del client, ad esempio utilizzando codici di controllo ANSI per nascondere file aggiuntivi in fase di trasferimento. Questo problema riguarda la funzione refresh_progress_meter() nel file progressmeter.c eseguiti con privilegi associati all'appartenenza ai gruppi del processo sshd, se la configurazione specifica l'esecuzione del comando come un utente diverso.
Impatto:	Possibile manipolazione dell'output del client e occultamento di file durante i trasferimenti

	SCP.
Soluzione:	Aggiornare OpenSSH a versioni successive e usare sftp al posto di scp per evitare la gestione insicura della progress bar.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2019-6109/ https://nvd.nist.gov/vuln/detail/CVE-2019-6109

Identificativo/ Livello:	CVE-2019-6110 / CVSS v3.0/v3.1: 6.8/10 (Medium)
Descrizione:	In OpenSSH 7.9, a causa della possibilità di accettare e visualizzare output stderr arbitrari dal server, un server malevolo (o un attaccante Man-in-the-Middle) può manipolare l'output del client, ad esempio utilizzando codici di controllo ANSI per nascondere file aggiuntivi in fase di trasferimento.
Impatto:	La vulnerabilità può consentire a un server SSH malevolo di manipolare l'output visualizzato al client durante trasferimenti SCP, inducendo l'utente a percepire informazioni false o nascoste.
Soluzione:	Il problema si risolve aggiornando OpenSSH a una versione successiva alla 7.9 e applicando le patch ufficiali che correggono la gestione dell'output remoto.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2019-6110/ https://nvd.nist.gov/vuln/detail/CVE-2019-6110

Identificativo/ Livello:	CVE-2016-0777 / CVSS v3.0/v3.1: 6.5/10 (Medium)
Descrizione:	La funzione resend_bytes presente nel file roaming_common.c del client OpenSSH nelle versioni 5.x, 6.x e 7.x precedenti alla 7.1p2 consente ai server remoti di ottenere informazioni sensibili dalla memoria di processo richiedendo la trasmissione di un intero buffer, come dimostrato dalla lettura di una chiave privata.
Impatto:	Un server SSH malevolo può sfruttare il roaming per estrarre informazioni sensibili dalla memoria del client, incluse possibili chiavi private.
Soluzione:	Aggiornare OpenSSH alla versione 7.1p2 o superiore oppure disattivare la funzione roaming.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-0777/ https://nvd.nist.gov/vuln/detail/CVE-2016-0777

Identificativo/ Livello:	CVE-2023-51385 / CVSS v3.0/v3.1: 6.5/10 (Medium)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 9.6, poteva verificarsi un'iniezione di comandi del sistema operativo se un nome utente o un nome host conteneva metacaratteri della shell e questo nome veniva referenziato da un token di espansione in determinate situazioni. Ad esempio, un repository Git non attendibile poteva avere un sottomodulo con metacaratteri della shell in un nome utente o in un nome host.
Impatto:	La vulnerabilità permette l'esecuzione di comandi arbitrari tramite hostname o username manipolati in OpenSSH.
Soluzione:	Aggiornare OpenSSH alla versione 9.6 o superiore e applicare le patch di sicurezza ufficiali.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2023-51385/ https://nvd.nist.gov/vuln/detail/CVE-2023-51385

Identificativo/ Livello:	CVE-2026-35387 / CVSS v3.0/v3.1: 6.5/10 (Medium)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 10.3, è possibile utilizzare algoritmi ECDSA non previsti. L'inclusione di qualsiasi algoritmo ECDSA in PubkeyAcceptedAlgorithms o HostbasedAcceptedAlgorithms viene erroneamente interpretata come riferita a tutti gli algoritmi ECDSA.
Impatto:	Aggiornare OpenSSH alla versione 10.3 o successiva per correggere la gestione delle configurazioni degli algoritmi.
Soluzione:	Aggiornare OpenSSH alla versione 10.3 o successiva per correggere la gestione delle configurazioni degli algoritmi.

Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-35387/ https://nvd.nist.gov/vuln/detail/CVE-2026-35387

Identificativo/ Livello:	CVE-2016-3115 / CVSS v3.0/v3.1: 6.4/10 (Medium)
Descrizione:	Molteplici vulnerabilità di iniezione CRLF in session.c in sshd in OpenSSH prima della 7.2p2 consentono agli utenti autenticati da remoto di aggirare le restrizioni previste sui comandi shell tramite dati di inoltro X11 appositamente creati, relativi alle funzioni (1) <code>do_authenticated1</code> e (2) <code>session_x11_req</code> .
Impatto:	La vulnerabilità consente a un utente autenticato di bypassare le restrizioni SSH ed eseguire comandi arbitrari tramite X11 forwarding manipolato.
Soluzione:	Aggiornare OpenSSH alla versione 7.2p2 o successiva per eliminare la possibilità di iniezione CRLF e correggere la gestione del forwarding X11.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-3115/ https://nvd.nist.gov/vuln/detail/CVE-2016-3115

Identificativo/ Livello:	CVE-2016-10011 / CVSS v3.0/v3.1: 5.5/10 (Medium)
Descrizione:	Il file <code>authfile.c</code> in <code>sshd</code> nelle versioni di OpenSSH precedenti alla 7.4 non considera correttamente gli effetti di <code>realloc</code> sul contenuto del buffer, il che potrebbe consentire agli utenti locali di ottenere informazioni sensibili sulla chiave privata sfruttando l'accesso a un processo figlio con privilegi separati.
Impatto:	La vulnerabilità può permettere a un utente locale di accedere a informazioni sensibili dalla memoria del processo <code>sshd</code> , inclusi possibili dati delle chiavi private.
Soluzione:	Aggiornare OpenSSH a una versione 7.4 o successiva, oppure applicare le patch di sicurezza rilasciate dal vendor per correggere la gestione della memoria nel componente interessato.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-10011/ https://nvd.nist.gov/vuln/detail/CVE-2016-10011

Identificativo/ Livello:	CVE-2018-15473 / CVSS v3.0/v3.1: 5.3/10 (Medium)
Descrizione:	OpenSSH fino alla versione 7.7 è soggetto a una vulnerabilità di enumerazione degli utenti dovuta al fatto che non ritarda l'uscita per un utente autenticato non valido fino a dopo che il pacchetto contenente la richiesta è stato completamente analizzato, correlata a <code>auth2-gss.c</code> , <code>auth2-hostbased.c</code> e <code>auth2-pubkey.c</code> .
Impatto:	Un attaccante remoto può sfruttare questa vulnerabilità per eseguire user enumeration, cioè identificare account validi sul sistema target analizzando le differenze nelle risposte del servizio SSH.
Soluzione:	Aggiornare OpenSSH alla versione 7.7 o successiva oppure applicare le patch di sicurezza che uniformano le risposte del processo di autenticazione.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2018-15473/ https://nvd.nist.gov/vuln/detail/CVE-2018-15473

Identificativo/ Livello:	CVE-2019-6111 / CVSS v3.0/v3.1: 5.9/10 (Medium)
Descrizione:	È stata scoperta una vulnerabilità in OpenSSH 7.9. Poiché l'implementazione di <code>scp</code> deriva da <code>rcp</code> del 1983, il server sceglie quali file/directory inviare al client. Tuttavia, il client <code>scp</code> esegue solo una convalida superficiale del nome dell'oggetto restituito (vengono impediti solo gli attacchi di directory traversal). Un server <code>scp</code> malevolo (o un attaccante Man-in-the-Middle) può sovrascrivere file arbitrari nella directory di destinazione del client <code>scp</code> . Se viene eseguita un'operazione ricorsiva (<code>-r</code>), il server può manipolare anche le sottodirectory (ad esempio, per sovrascrivere il file <code>.ssh/authorized_keys</code>).
Impatto:	La vulnerabilità consente a un server SCP malevolo di sovrascrivere file locali sul client durante il trasferimento.
Soluzione:	Aggiornare OpenSSH e utilizzare protocolli sicuri come SFTP per evitare la manipolazione dei file durante il trasferimento.

Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2019-6111/ https://nvd.nist.gov/vuln/detail/CVE-2019-6111

Identificativo/ Livello:	CVE-2020-14145 / CVSS v3.0/v3.1: 5.9/10 (Medium)
Descrizione:	Il lato client di OpenSSH, nelle versioni dalla 5.7 alla 8.4, presenta una discrepanza osservabile che porta a una fuga di informazioni nella negoziazione dell'algoritmo. Ciò consente agli aggressori man-in-the-middle di prendere di mira i tentativi di connessione iniziali (quando la chiave host del server non è stata memorizzata nella cache dal client). NOTA: alcune segnalazioni indicano che anche le versioni 8.5 e 8.6 sono interessate.
Impatto:	La vulnerabilità consente a un attaccante Man-in-the-Middle di ottenere informazioni sulle connessioni SSH durante la negoziazione iniziale degli algoritmi.
Soluzione:	Aggiornare OpenSSH a una versione superiore alla 8.4 e applicare le patch di sicurezza ufficiali.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2020-14145/ https://nvd.nist.gov/vuln/detail/CVE-2020-14145

Identificativo/ Livello:	CVE-2023-48795 / CVSS v3.0/v3.1: 5.9/10 (Medium)
Descrizione:	La vulnerabilità riguarda il protocollo SSH (incluso OpenSSH < 9.6) ed è causata da un difetto nel SSH Binary Packet Protocol, che permette a un attaccante Man-in-the-Middle di manipolare la fase di handshake e rimuovere alcuni pacchetti durante la negoziazione, portando a una possibile degradazione o disattivazione di funzionalità di sicurezza della connessione SSH (attacco noto come <i>Terrapin</i>).
Impatto:	La vulnerabilità consente a un attaccante Man-in-the-Middle di manipolare la negoziazione SSH e indebolire la sicurezza della connessione.
Soluzione:	Aggiornare OpenSSH alla versione 9.6 o superiore e applicare le patch che correggono la gestione del protocollo SSH.
Detection:	Analisi Manuale/ Nessus
Riferimenti:	https://www.cvedetails.com/cve/CVE-2023-48795/ https://nvd.nist.gov/vuln/detail/CVE-2023-48795

Identificativo/ Livello:	CVE-2016-20012 / CVSS v3.0/v3.1: 5.3/10 (Medium)
Descrizione:	OpenSSH fino alla versione 8.7 consente agli aggressori remoti, che sospettano che una determinata combinazione di nome utente e chiave pubblica sia nota a un server SSH, di verificare se tale sospetto sia fondato. Ciò avviene perché viene inviata una richiesta di autenticazione solo quando tale combinazione potrebbe risultare valida per una sessione di accesso.
Impatto:	La vulnerabilità consente a un attaccante remoto di verificare combinazioni valide di username e chiave pubblica tramite differenze nel processo di autenticazione SSH.
Soluzione:	Applicare le patch di OpenSSH o aggiornare a versioni che uniformano le risposte del server durante l'autenticazione per impedire l'enumerazione.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-20012/ https://nvd.nist.gov/vuln/detail/CVE-2016-20012

Identificativo/ Livello:	CVE-2017-15906 / CVSS v3.0/v3.1: 5.3/10 (Medium)
Descrizione:	La funzione process_open presente nel file sftp-server.c di OpenSSH, nelle versioni precedenti alla 7.6, non impedisce correttamente le operazioni di scrittura in modalità di sola lettura, consentendo così agli aggressori di creare file di lunghezza zero.
Impatto:	La vulnerabilità consente a un utente remoto autenticato di creare file vuoti anche in modalità read-only tramite SFTP.
Soluzione:	Aggiornare OpenSSH alla versione 7.6 o successiva per correggere la gestione delle operazioni di scrittura nel server SFTP.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2017-15906/ https://nvd.nist.gov/vuln/detail/CVE-2017-15906

Identificativo/ Livello:	CVE-2018-15919 / CVSS v3.0/v3.1: 5.3/10 (Medium)
Descrizione:	Un comportamento osservabile da remoto nel file auth-gss2.c di OpenSSH fino alla versione 7.8 potrebbe essere utilizzato da malintenzionati remoti per rilevare la presenza di utenti su un sistema target quando è in uso GSS2. NOTA: chi ha scoperto la vulnerabilità afferma: "Comprendiamo che gli sviluppatori di OpenSSH non vogliano considerare tale enumerazione di nomi utente (o "oracolo") come una vulnerabilità".
Impatto:	La vulnerabilità consente a un attaccante remoto di identificare utenti validi su un server OpenSSH tramite differenze osservabili durante l'autenticazione GSSAPI.
Soluzione:	Aggiornare OpenSSH a una versione successiva alla 7.8 o applicare le patch che eliminano la possibilità di user enumeration.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2018-15919/ https://nvd.nist.gov/vuln/detail/CVE-2018-15919

Identificativo/ Livello:	CVE-2015-5352 / CVSS v2.0: 4.3/10 (Medium)
Descrizione:	La funzione x11_open_helper in channels.c di ssh in OpenSSH prima della versione 6.9, quando non viene utilizzata la modalità ForwardX11Trusted, non effettua un controllo sulla scadenza del rifiuto per le connessioni X, il che facilita agli aggressori remoti l'elusione delle restrizioni di accesso previste tramite una connessione al di fuori della finestra temporale consentita.
Impatto:	La vulnerabilità consente a un attaccante remoto di bypassare le restrizioni X11 forwarding e aprire connessioni non autorizzate oltre il tempo consentito.
Soluzione:	Aggiornare OpenSSH alla versione 6.9 o successiva per correggere la gestione del timeout delle connessioni X11.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2015-5352/ https://nvd.nist.gov/vuln/detail/CVE-2015-5352

Identificativo/ Livello:	Apple Mac OS X Find-By-Content .DS_Store Web Directory Listing CVE-2001-1446 / CVSS v3.0: 5.3/10 (Medium)
Descrizione:	È possibile leggere un file '.DS_Store' sul server web remoto. Questo file viene creato dal Finder di macOS X; viene utilizzato, tra le altre cose, per memorizzare la posizione delle icone sul desktop e contiene l'elenco dei file e delle directory presenti nella directory remota. Si noti che i file eliminati potrebbero essere ancora presenti in questo file .DS_Store.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per provocare un Denial of Service (DoS) del servizio SSH, rendendo il sistema non raggiungibile tramite connessione remota e interrompendo l'accesso amministrativo.
Soluzione:	Il problema viene risolto configurando il server web per negare l'accesso ai file .DS_Store e disabilitando sui sistemi macOS la creazione automatica di tali file sulle condivisioni di rete.
Detection:	Nessus
Riferimenti:	https://www.cve.org/CVERecord?id=CVE-2001-1446

Identificativo/ Livello:	Browsable Web Directories CVE - / CVSS v3.0: 5.3/10 (Medium)
Descrizione:	Diversi plugin di Nessus hanno identificato directory sul server web che sono accessibili tramite browser.
Impatto:	La vulnerabilità consente a un attaccante remoto di visualizzare la struttura delle directory del server web e i file presenti, facilitando attività di ricognizione.
Soluzione:	Disabilitare il directory listing e applicare restrizioni di accesso alle directory sensibili tramite configurazione del web server.
Detection:	Nessus
Riferimenti:	Report Nessus

Identificativo/ Livello:	JQuery 1.2 < 3.5.0 Multiple XSS CVE 2020-11022 - CVE-2020-11023 / CVSS v3.0: 6.1/10 (Medium) – CWE 1395
Descrizione:	Secondo la versione autodichiarata nello script, la versione di jQuery ospitata sul server web remoto è maggiore o uguale alla 1.2 e precedente alla 3.5.0. È pertanto interessata da diverse vulnerabilità di cross-site scripting.
Impatto:	La vulnerabilità consente a un attaccante remoto di eseguire codice JavaScript malevolo nel browser della vittima tramite Cross-Site Scripting (XSS) in jQuery vulnerabile.
Soluzione:	Aggiornare jQuery alla versione 3.5.0 o successiva.
Detection:	Nessus /OWASP ZAP
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2020-11022 https://www.cve.org/CVERecord?id=CVE-2020-11022 https://nvd.nist.gov/vuln/detail/CVE-2020-11023 https://www.cve.org/CVERecord?id=CVE-2020-11023 https://cwe.mitre.org/data/definitions/1395.html

Identificativo/ Livello:	Web Application Information Disclosure CVSS v2.0: 5.0/10 (Medium)
Descrizione:	La web application remota è vulnerabile a una information disclosure, in quanto alcune richieste HTTP malformate provocano la restituzione di messaggi di errore che includono informazioni sul percorso fisico (path) delle directory del server.
Impatto:	La vulnerabilità consente a un attaccante remoto di ottenere informazioni sulla struttura interna del server web tramite messaggi di errore che rivelano i percorsi delle directory.
Soluzione:	Disabilitare la visualizzazione di informazioni sensibili nei messaggi di errore e configurare correttamente la gestione degli errori dell'applicazione web.
Detection:	Nessus
Riferimenti:	Report Nessus

Identificativo/ Livello:	Web Application Information Disclosure CVSS v2.0: 5.0/10 (Medium)
Descrizione:	La web application remota è vulnerabile a una information disclosure, in quanto alcune richieste HTTP malformate provocano la restituzione di messaggi di errore che includono informazioni sul percorso fisico (path) delle directory del server.
Impatto:	La vulnerabilità consente a un attaccante remoto di ottenere informazioni sulla struttura interna del server web tramite messaggi di errore che rivelano i percorsi delle directory.
Soluzione:	Disabilitare la visualizzazione di informazioni sensibili nei messaggi di errore e configurare correttamente la gestione degli errori dell'applicazione web.
Detection:	Nessus
Riferimenti:	Report Nessus

Identificativo/ Livello:	Clickjacking Protection Missing (X-Frame-Options / CSP frame-ancestors) CVSS v2.0: 4.3 / 10 (Medium)
Descrizione:	La web application remota non implementa le corrette misure di protezione contro gli attacchi di clickjacking, in quanto non viene impostato l'header HTTP X-Frame-Options né la direttiva Content-Security-Policy.
Impatto:	Consente a un attaccante remoto di eseguire attacchi di clickjacking inducendo l'utente a compiere azioni non intenzionali all'interno della web application.
Soluzione:	Implementare gli header X-Frame-Options o Content-Security-Policy (frame-ancestors) per impedire il caricamento del sito in iframe esterni.
Detection:	Nessus
Riferimenti:	Report Nessus

Identificativo/ Livello:	WordPress User Enumeration (Information Disclosure) CVSS v2.0: 5.0 / 10 (Medium)
--------------------------	---

Descrizione:	La versione di WordPress presente sul server remoto consente a un attaccante non autenticato di effettuare user enumeration, ovvero l'identificazione di utenti validi registrati sulla piattaforma.
Impatto:	Un attaccante remoto può sfruttare questa vulnerabilità per ottenere informazioni sugli username validi di WordPress, facilitando attacchi successivi come brute force password guessing o credential stuffing.
Soluzione:	Configurare WordPress per impedire l'enumerazione degli utenti tramite hardening e plugin di sicurezza.
Detection:	Nessus
Riferimenti:	Report Nessus

Identificativo/ Livello:	CVE-2018-20147 / CVSS v3.0: 6.5/10 (Medium)
Descrizione:	Nelle versioni di WordPress precedenti alla 4.9.9 e nelle versioni 5.x precedenti alla 5.0.1, gli autori potevano modificare i metadati per aggirare le restrizioni previste sull'eliminazione dei file.
Impatto:	La vulnerabilità consente a un utente autenticato di bypassare le restrizioni di WordPress e modificare o eliminare file tramite manipolazione dei metadati.
Soluzione:	Aggiornare WordPress alla versione 4.9.9 o successiva per correggere la gestione delle autorizzazioni sui metadati.
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2018-20147

Identificativo/ Livello:	CVE-2018-20149 / CVSS v3.0: 5.4/10 (Medium)
Descrizione:	Nelle versioni di WordPress precedenti alla 4.9.9 e nelle versioni 5.x precedenti alla 5.0.1, quando veniva utilizzato il server HTTP Apache, gli autori potevano caricare file appositamente creati per aggirare le restrizioni previste sui tipi MIME, portando a vulnerabilità XSS, come dimostrato da un file .jpg privo di dati JPEG.
Impatto:	La vulnerabilità consente a un autore autenticato di caricare file manipolati che bypassano il controllo MIME type, causando possibili attacchi XSS.
Soluzione:	Aggiornare WordPress alla versione 4.9.9 o superiore per correggere la validazione dei file caricati.
Detection:	Analisi Manuale
Riferimenti:	https://www.cve.org/CVERecord?id=CVE-2018-20149 https://nvd.nist.gov/vuln/detail/CVE-2018-20149

Identificativo/ Livello:	CVE-2018-20150 / CVSS v3.0: 6.1 / 10 (Medium)
Descrizione:	Nelle versioni di WordPress precedenti alla 4.9.9 e nelle versioni 5.x precedenti alla 5.0.1, gli URL appositamente creati potevano attivare vulnerabilità XSS in determinati casi d'uso che coinvolgevano i plugin.
Impatto:	La vulnerabilità consente a un attaccante remoto di eseguire codice JavaScript malevolo tramite URL manipolati che causano Cross-Site Scripting (XSS).
Soluzione:	Aggiornare WordPress alla versione 4.9.9 o superiore per correggere la gestione degli URL e prevenire XSS.
Detection:	Analisi Manuale
Riferimenti:	https://www.cve.org/CVERecord?id=CVE-2018-20150 https://nvd.nist.gov/vuln/detail/CVE-2018-20150

Identificativo/ Livello:	CVE-2018-20152 / CVSS v3.0: 6.5 / 10 (Medium)
Descrizione:	Nelle versioni di WordPress precedenti alla 4.9.9 e nelle versioni 5.x precedenti alla 5.0.1, gli autori potevano aggirare le restrizioni previste sui tipi di post tramite input appositamente creati.
Impatto:	La vulnerabilità consente a un utente autore autenticato di bypassare le restrizioni sui tipi di post e pubblicare contenuti non autorizzati.
Soluzione:	Aggiornare WordPress alla versione 4.9.9 o superiore per correggere la validazione degli input e dei post type.
Detection:	Analisi Manuale

Riferimenti:	https://www.cve.org/CVERecord?id=CVE-2018-20152 https://nvd.nist.gov/vuln/detail/CVE-2018-20152
--------------	--

Identificativo/ Livello:	CVE-2018-20153 / CVSS v3.0: 5.4 / 10 (Medium)
Descrizione:	Nelle versioni di WordPress precedenti alla 4.9.9 e nelle versioni 5.x precedenti alla 5.0.1, i collaboratori potevano modificare i nuovi commenti inseriti da utenti con privilegi più elevati, causando potenzialmente una vulnerabilità XSS.
Impatto:	La vulnerabilità consente a un utente contributor di modificare commenti e inserire codice XSS nel sito WordPress.
Soluzione:	Aggiornare WordPress alla versione 4.9.9 o superiore per correggere la gestione dei permessi sui commenti.
Detection:	Analisi Manuale
Riferimenti:	https://www.cve.org/CVERecord?id=CVE-2018-20153 https://nvd.nist.gov/vuln/detail/CVE-2018-20153

Identificativo/ Livello:	Absence of Anti-CSRF Tokens / CWE-352
Descrizione:	La debolezza consiste nell'assenza di token Anti-CSRF nelle richieste HTTP, il che permette a un attaccante di forgiare richieste malevole che vengono eseguite nel contesto di una sessione autenticata dell'utente. Questo tipo di attacco sfrutta la fiducia del sito verso il browser dell'utente.
Impatto:	Un attaccante può indurre un utente autenticato a eseguire azioni indesiderate sul sistema, come modifiche a dati o configurazioni, compromettendo l'integrità delle operazioni.
Soluzione:	Implementare token Anti-CSRF univoci e validi per ogni sessione e richiesta sensibile, verificandoli lato server per ogni operazione che modifica lo stato dell'applicazione.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/352.html

Identificativo/ Livello:	Content Security Policy (CSP) Header Not Set / CWE-693
Descrizione:	La debolezza indica l'assenza dell'header HTTP Content Security Policy (CSP), che serve a definire quali risorse esterne il browser può caricare ed eseguire. Senza questo controllo, il browser non applica restrizioni contro contenuti non autorizzati.
Impatto:	Maggiore esposizione ad attacchi di tipo Cross-Site Scripting (XSS) e injection di contenuti malevoli, poiché non esistono politiche che limitano l'esecuzione di script o risorse non fidate.
Soluzione:	Configurare l'header Content-Security-Policy nel server web definendo fonti consentite per script, stili, immagini e altre risorse, riducendo al minimo le origini affidabili.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/693.html

Identificativo/ Livello:	HTTP to HTTPS Insecure Transition in Form Post / CWE-319
Descrizione:	La debolezza si verifica quando un form viene inviato da una pagina HTTP a una pagina HTTPS, esponendo potenzialmente i dati durante il transito iniziale. Questo può permettere l'intercettazione delle informazioni prima della cifratura.
Impatto:	Possibile intercettazione di dati sensibili trasmessi tramite form, con rischio di furto di credenziali o informazioni personali.
Soluzione:	Forzare l'utilizzo esclusivo di HTTPS tramite redirect automatici e configurare HSTS per garantire che tutte le comunicazioni avvengano su canale cifrato.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/319.html

Identificativo/ Livello:	Missing Anti-clickjacking Header / CWE-1021
--------------------------	---

Descrizione:	La debolezza indica l'assenza di header di protezione contro il clickjacking, come X-Frame-Options o Content-Security-Policy frame-ancestors, permettendo l'incorporamento della pagina in iframe malevoli.
Impatto:	Possibile esecuzione di azioni ingannevoli da parte dell'utente tramite interfacce nascoste o sovrapposte, compromettendo l'integrità delle interazioni.
Soluzione:	Impostare l'header X-Frame-Options (DENY o SAMEORIGIN) oppure utilizzare CSP frame-ancestors per impedire il caricamento della pagina in iframe non autorizzati.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/1021.html

Identificativo/ Livello:	Sub Resource Integrity Attribute Missing / CWE-345
Descrizione:	La debolezza indica l'assenza dell'attributo Subresource Integrity (SRI) nei file esterni caricati. Senza SRI, il browser non può verificare che le risorse esterne non siano state modificate rispetto alla versione originale.
Impatto:	Possibile esecuzione di codice malevolo se una risorsa esterna viene compromessa o manomessa, con rischio di attacchi di tipo supply chain o injection di script.
Soluzione:	Aggiungere l'attributo integrity con hash crittografico (SHA-256/384/512) ai tag script e link che caricano risorse esterne, garantendo la verifica dell'integrità.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/345.html

Identificativo/ Livello:	CVE-2025-65082 – CVSS v3.1: 6.5/10 (Medium)
Descrizione:	Vulnerabilità di neutralizzazione impropria delle sequenze Escape, Meta o Control nel server HTTP Apache, dovuta a variabili d'ambiente impostate tramite la configurazione di Apache che sovrascrivono inaspettatamente le variabili calcolate dal server per i programmi CGI. Questo problema interessa le versioni di Apache HTTP Server dalla 2.4.0 alla 2.4.65.
Impatto:	Un attaccante remoto può influenzare il comportamento delle applicazioni CGI, con possibile esposizione o modifica limitata dei dati elaborati dal server, compromettendo parzialmente la riservatezza e l'integrità del sistema.
Soluzione:	Si consiglia agli utenti di aggiornare alla versione 2.4.66, che risolve il problema.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2025-65082/ https://nvd.nist.gov/vuln/detail/CVE-2025-65082

Identificativo/ Livello:	CVE-2026-43951 – CVSS v3.1: 6.5/10 (Medium)
Descrizione:	Vulnerabilità di lettura fuori dai limiti nel server HTTP Apache con mod_headers e mod_mime e più lingue di risposta. Questo problema interessa il server HTTP Apache dalla versione 2.4.0 alla 2.4.67.
Impatto:	Un attaccante remoto può sfruttare la vulnerabilità per leggere dati oltre i limiti previsti della memoria, causando una limitata esposizione di informazioni sensibili e una parziale compromissione dell'integrità dei dati, senza influire sulla disponibilità del servizio.
Soluzione:	Aggiornare Apache HTTP Server alla versione corretta successiva alla 2.4.67 e mantenere il server costantemente aggiornato con gli ultimi aggiornamenti di sicurezza.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-43951/ https://nvd.nist.gov/vuln/detail/CVE-2026-43951

Identificativo/ Livello:	CVE-2024-24795 – CVSS v3.1: 6.3/10 (Medium)
Descrizione:	La suddivisione della risposta HTTP in più moduli nel server Apache HTTP consente a un utente malintenzionato di inserire intestazioni di risposta dannose nelle applicazioni backend per provocare un attacco di desincronizzazione HTTP.
Impatto:	Può consentire la manipolazione delle risposte HTTP, con possibili attacchi di desincronizzazione tra client, proxy e server, compromettendo parzialmente la riservatezza, l'integrità e la disponibilità delle comunicazioni.
Soluzione:	Si consiglia agli utenti di eseguire l'aggiornamento alla versione 2.4.59, che risolve questo

	problema.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2024-24795/ https://nvd.nist.gov/vuln/detail/CVE-2024-24795

Identificativo/ Livello:	CVE-2016-4975 – CVSS v3.0: 6.1/10 (Medium)
Descrizione:	Possibile iniezione di CRLF che consente attacchi di HTTP response splitting per i siti che utilizzano mod_userdir. Questo problema è stato mitigato dalle modifiche apportate nelle versioni 2.4.25 e 2.2.32 che impediscono l'iniezione di CR o LF nella chiave o nel valore dell'intestazione in uscita "Location" o di altre. Corretto in Apache HTTP Server 2.4.25 (versioni interessate: 2.4.1-2.4.23). Corretto in Apache HTTP Server 2.2.32 (versioni interessate: 2.2.0-2.2.31).
Impatto:	Può consentire la manipolazione delle risposte HTTP, favorendo attacchi come cache poisoning, reindirizzamenti o altre alterazioni del traffico web, con compromissione della riservatezza e dell'integrità delle comunicazioni.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.25 (o successiva) oppure alla 2.2.32 per il ramo 2.2, che impediscono l'iniezione di caratteri CR/LF negli header HTTP.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-4975/ https://nvd.nist.gov/vuln/detail/CVE-2016-4975

Identificativo/ Livello:	CVE-2019-10092– CVSS v3.0: 6.1/10 (Medium)
Descrizione:	Nelle versioni di Apache HTTP Server 2.4.0-2.4.39, è stata segnalata una vulnerabilità di cross-site scripting (CSScript) limitata che interessava la pagina di errore di mod_proxy. Un utente malintenzionato poteva causare la formattazione errata del link nella pagina di errore, reindirizzandolo a una pagina a sua scelta. Questa vulnerabilità era sfruttabile solo se il server era configurato con il proxy abilitato, ma presentava una configurazione errata che causava la visualizzazione della pagina di errore del proxy.
Impatto:	Può consentire attacchi di phishing o l'esecuzione di codice JavaScript nel browser dell'utente, compromettendo parzialmente la riservatezza e l'integrità dei dati. È richiesta l'interazione dell'utente con il collegamento malevolo.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.40 o successiva e verificare che la configurazione di mod_proxy non esponga pagine di errore accessibili o configurate in modo non corretto.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2019-10092/ https://nvd.nist.gov/vuln/detail/CVE-2019-10092

Identificativo/ Livello:	CVE-2019-10098– CVSS v3.0: 6.1/10 (Medium)
Descrizione:	Nelle versioni del server HTTP Apache dalla 2.4.0 alla 2.4.39, i reindirizzamenti configurati con mod_rewrite, che avrebbero dovuto essere autoreferenziali, potrebbero essere ingannati da caratteri di nuova riga codificati e reindirizzare invece a un URL inatteso all'interno dell'URL della richiesta.
Impatto:	Un attaccante può indurre gli utenti a essere reindirizzati verso siti malevoli, favorendo attacchi di phishing o il furto di credenziali. Lo sfruttamento richiede l'interazione dell'utente con un collegamento appositamente predisposto.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.40 o successiva, che corregge la vulnerabilità, e verificare che le regole di mod_rewrite validino correttamente gli URL di destinazione dei redirect.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2019-10098/ https://nvd.nist.gov/vuln/detail/CVE-2019-10098

Identificativo/ Livello:	CVE-2020-1927– CVSS v3.0: 6.1/10 (Medium)
Descrizione:	In Apache HTTP Server da 2.4.0 a 2.4.41, i reindirizzamenti configurati con mod_rewrite che dovevano essere autoreferenziali potrebbero essere ingannati da caratteri di fine riga

	codificati e reindirizzare invece a un URL imprevisto all'interno dell'URL della richiesta.
Impatto:	Un attaccante può indurre gli utenti a essere reindirizzati verso siti malevoli, favorendo attacchi di phishing o il furto di credenziali. Lo sfruttamento richiede l'interazione dell'utente con un collegamento appositamente predisposto.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.42 o successiva e verificare che le regole di mod_rewrite validino correttamente gli URL di destinazione dei redirect.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2020-1927/ https://nvd.nist.gov/vuln/detail/CVE-2020-1927

Identificativo/ Livello:	CVE-2026-29170– CVSS v3.0: 6.1/10 (Medium)
Descrizione:	Esiste una vulnerabilità di cross-site scripting (CSScript) nella generazione dell'elenco di directory HTML del modulo mod_proxy_ftp nelle versioni 2.4.67 e precedenti di Apache HTTP Server, quando si elenca il contenuto delle directory FTP tramite configurazione proxy forward o reverse. Si consiglia agli utenti di aggiornare alla versione 2.4.68, che risolve questo problema.
Impatto:	Un attaccante può eseguire script nel browser dell'utente, facilitando il furto di credenziali, cookie di sessione o altre informazioni sensibili. Lo sfruttamento richiede l'interazione dell'utente con la pagina contenente l'elenco FTP.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.68 o successiva, che corregge la vulnerabilità, e limitare l'esposizione delle directory FTP tramite mod_proxy_ftp se non strettamente necessario.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-29170/ https://nvd.nist.gov/vuln/detail/CVE-2026-29170

Identificativo/ Livello:	CVE-2018-1301 – CVSS v3.0: 5.9/10 (Medium)
Descrizione:	Una richiesta appositamente creata avrebbe potuto mandare in crash il server HTTP Apache prima della versione 2.4.30, a causa di un accesso fuori dai limiti dopo il raggiungimento di un limite di dimensione durante la lettura dell'intestazione HTTP. Questa vulnerabilità è considerata molto difficile, se non impossibile, da attivare in modalità non di debug (sia a livello di log che di build), pertanto è classificata a basso rischio per l'utilizzo comune del server.
Impatto:	Un attaccante remoto può causare un Denial of Service (DoS), interrompendo temporaneamente la disponibilità del server. Nelle configurazioni standard il rischio di sfruttamento è considerato basso.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.30 o successiva, che corregge la vulnerabilità, mantenendo il server aggiornato con le ultime patch di sicurezza.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2018-1301/ https://nvd.nist.gov/vuln/detail/CVE-2018-1301

Identificativo/ Livello:	CVE-2018-1302 – CVSS v3.0: 5.9/10 (Medium)
Descrizione:	Quando uno stream HTTP/2 veniva distrutto dopo essere stato gestito, il server HTTP Apache, nelle versioni precedenti alla 2.4.30, poteva scrivere un puntatore NULL potenzialmente in una memoria già liberata. I pool di memoria gestiti dal server rendono difficile attivare questa vulnerabilità nelle configurazioni standard; il segnalatore e il team non sono riusciti a riprodurla al di fuori delle build di debug, pertanto è classificata come a basso rischio.
Impatto:	Un attaccante remoto può provocare un Denial of Service (DoS), causando il crash del server Apache. L'exploitation è considerata difficile e poco probabile in configurazioni standard, ma può comunque influire sulla disponibilità del servizio.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.30 o successiva, dove il problema è stato corretto. In alternativa, ridurre l'esposizione di HTTP/2 se non necessario o disabilitarlo temporaneamente come mitigazione.
Detection:	Analisi manuale

Riferimenti:	https://www.cvedetails.com/cve/CVE-2018-1302/ https://nvd.nist.gov/vuln/detail/CVE-2018-1302
--------------	--

Identificativo/ Livello:	CVE-2026-44119 – CVSS v3.1: 5.5/10 (Medium)
Descrizione:	Una vulnerabilità di gestione dei privilegi non corretta in Apache HTTP Server 2.4.67 e versioni precedenti consente agli autori locali di file .htaccess di leggere i file con i privilegi dell'utente httpd. Questo problema interessa anche Apache HTTP Server dalla versione 2.4.67 alla 2.4.68.
Impatto:	Un attaccante con accesso alla possibilità di creare o modificare file .htaccess può ottenere lettura non autorizzata di file sensibili del server, con impatto sulla riservatezza dei dati, ma senza esecuzione di codice remoto o impatto diretto sulla disponibilità.
Soluzione:	Si consiglia agli utenti di aggiornare alla versione 2.4.68, che risolve il problema.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-44119/ https://nvd.nist.gov/vuln/detail/CVE-2026-44119

Identificativo/ Livello:	CVE-2020-13938– CVSS v3.1: 5.5/10 (Medium)
Descrizione:	Versioni del server HTTP Apache dalla 2.4.0 alla 2.4.46 Gli utenti locali non privilegiati possono arrestare httpd su Windows
Impatto:	Un attaccante locale con privilegi bassi può provocare un Denial of Service (DoS) fermando Apache HTTP Server, compromettendo la disponibilità del servizio, ma senza accesso diretto a dati o esecuzione remota di codice.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.47 o successiva, che corregge la vulnerabilità, e applicare correttamente le policy di sicurezza su sistemi Windows per impedire agli utenti locali non autorizzati di interferire con il servizio.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2020-13938/ https://nvd.nist.gov/vuln/detail/CVE-2020-13938

Identificativo/ Livello:	CVE-2018-1283 – CVSS v3.0: 5.3/10 (Medium)
Descrizione:	Nelle versioni di Apache httpd dalla 2.4.0 alla 2.4.29, quando mod_session è configurato per inoltrare i dati di sessione alle applicazioni CGI (SessionEnv attivo, non predefinito), un utente remoto può influenzarne il contenuto utilizzando un'intestazione "Session". Ciò deriva dal nome della variabile "HTTP_SESSION" utilizzata da mod_session per inoltrare i dati alle applicazioni CGI, poiché il prefisso "HTTP_" viene utilizzato anche dal server HTTP Apache per trasmettere i campi dell'intestazione HTTP, secondo le specifiche CGI.
Impatto:	Un attaccante può manipolare i dati di sessione passati ai CGI, alterando il comportamento dell'applicazione web. Questo può portare a alterazione dei contenuti, bypass logici o modifica delle risposte dell'applicazione, con impatto su integrità e parzialmente sulla riservatezza, ma senza esecuzione di codice remoto diretta.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.30 o successiva, oppure disabilitare o rivedere la configurazione di mod_session (SessionEnv) se non strettamente necessaria, per evitare che i dati di sessione vengano influenzati da input non fidati.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2018-1283/ https://nvd.nist.gov/vuln/detail/CVE-2018-1283

Identificativo/ Livello:	CVE-2019-0220– CVSS v3.0: 5.3/10 (Medium)
Descrizione:	È stata rilevata una vulnerabilità in Apache HTTP Server da 2.4.0 a 2.4.38. Quando il componente percorso di un URL di richiesta contiene più barre consecutive ('/'), direttive come LocationMatch e RewriteRule devono tenere conto dei duplicati nelle espressioni regolari mentre altri aspetti dell'elaborazione dei server li comprimeranno implicitamente.
Impatto:	Un attaccante può sfruttare questa inconsistenza per bypassare regole di accesso o di rewrite, potenzialmente accedendo a risorse non previste o aggirando restrizioni di sicurezza. L'impatto principale riguarda integrità e controllo degli accessi, con possibili scenari di bypass di protezioni applicative.

Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.39 o successiva, dove il comportamento di normalizzazione degli URL e delle regole di matching è stato corretto. In alternativa, rivedere le regole di RewriteRule/LocationMatch per gestire correttamente URL con slash multipli e ridurre superfici di bypass.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2019-0220/ https://nvd.nist.gov/vuln/detail/CVE-2019-0220

Identificativo/ Livello:	CVE-2020-1934 – CVSS v3.0: 5.3/10 (Medium)
Descrizione:	In Apache HTTP Server da 2.4.0 a 2.4.41, mod_proxy_ftp potrebbe utilizzare memoria non inizializzata durante l'inoltro a un server FTP dannoso.
Impatto:	Un attaccante remoto che controlla o compromette un server FTP può causare lettura di memoria non inizializzata, con possibile esposizione di informazioni sensibili presenti in memoria del processo Apache. L'impatto principale riguarda quindi la riservatezza dei dati, senza esecuzione di codice remoto diretta o impatto sulla disponibilità.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.42 o successiva, dove il problema è stato corretto. In alternativa, disabilitare o limitare l'uso di mod_proxy_ftp se non strettamente necessario, riducendo così la superficie di attacco.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2020-1934/ https://nvd.nist.gov/vuln/detail/CVE-2020-1934

Identificativo/ Livello:	CVE-2020-11985 – CVSS v3.0: 5.3/10 (Medium)
Descrizione:	Spoofing dell'indirizzo IP durante l'utilizzo di proxy con mod_remoteip e mod_rewrite. Nelle configurazioni che utilizzano il proxy con mod_remoteip e determinate regole di mod_rewrite, un utente malintenzionato potrebbe falsificare il proprio indirizzo IP per i log e gli script PHP. Si noti che questo problema è stato risolto in Apache HTTP Server 2.4.24, ma nel 2020 gli è stato assegnato retroattivamente un CVE di bassa gravità.
Impatto:	Un attaccante remoto può falsificare il proprio indirizzo IP, influenzando log, sistemi di monitoraggio e applicazioni (ad esempio PHP) che si basano sull'IP per controlli di sicurezza. Questo può portare a bypass di restrizioni basate su IP e alterazione dei log di accesso, con impatto su integrità e tracciabilità delle attività.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.24 o successiva (dove il problema è stato corretto) e rivedere la configurazione di mod_remoteip e mod_rewrite per evitare che header non fidati vengano utilizzati per determinare l'IP del client.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2020-11985/ https://nvd.nist.gov/vuln/detail/CVE-2020-11985

Identificativo/ Livello:	CVE-2022-28614– CVSS v3.0: 5.3/10 (Medium)
Descrizione:	La funzione ap_rwrite() in Apache HTTP Server 2.4.53 e versioni precedenti potrebbe leggere memoria in modo non autorizzato se un utente malintenzionato riesce a far sì che il server rifletta input molto grandi utilizzando ap_rwrite() o ap_rputs(), ad esempio con la funzione r:puts() del modulo mod_lua. I moduli compilati e distribuiti separatamente da Apache HTTP Server che utilizzano la funzione 'ap_rputs' e che potrebbero passarle una stringa molto grande (INT_MAX o superiore) devono essere compilati con gli header correnti per risolvere il problema.
Impatto:	Possibile esposizione di dati sensibili dalla memoria del server (riservatezza).
Soluzione:	Aggiornare a Apache HTTP Server 2.4.54 o successiva.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2022-28614/ https://nvd.nist.gov/vuln/detail/CVE-2022-28614

Identificativo/ Livello:	CVE-2022-37436– CVSS v3.0: 5.3/10 (Medium)
Descrizione:	Prima della versione 2.4.55 di Apache HTTP Server, un backend malevolo poteva causare il troncamento anticipato delle intestazioni di risposta, con la conseguenza che alcune di

	esse venivano incorporate nel corpo della risposta. Se queste intestazioni successive avevano una funzione di sicurezza, non sarebbero state interpretate dal client.
Impatto:	Possibile alterazione della risposta HTTP e bypass parziale di controlli di sicurezza lato client/server (es. header di sicurezza non applicati correttamente), con impatto su integrità e in parte riservatezza.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.55 o successiva e verificare la configurazione di mod_proxy per evitare backend non affidabili.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2022-37436/ https://nvd.nist.gov/vuln/detail/CVE-2022-37436

Identificativo/ Livello:	CVE-2026-33007– CVSS v3.0: 5.3/10 (Medium)
Descrizione:	Un dereferenzamento del puntatore NULL in mod_auth_socache in Apache HTTP Server 2.4.66 e versioni precedenti consente a un utente remoto non autenticato di arrestare in modo anomalo un processo figlio in una configurazione del proxy di inoltro nella cache.
Impatto:	Un attaccante remoto può provocare un Denial of Service (crash del server), riducendo la disponibilità del servizio.
Soluzione:	Si consiglia agli utenti di eseguire l'aggiornamento alla versione 2.4.67, che risolve questo problema
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-33007/ https://nvd.nist.gov/vuln/detail/CVE-2026-33007

Identificativo/ Livello:	CVE-2026-33857– CVSS v3.0: 5.3/10 (Medium)
Descrizione:	Vulnerabilità di lettura fuori dai limiti nel modulo mod_proxy_ajp del server HTTP Apache. Questo problema interessa le versioni di Apache HTTP Server fino alla 2.4.66.
Impatto:	Possibile lettura di informazioni dalla memoria del processo Apache, con impatto sulla riservatezza (data leakage limitato), senza esecuzione di codice o impatto diretto sulla disponibilità.
Soluzione:	Si consiglia agli utenti di aggiornare alla versione 2.4.67, che risolve il problema.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-33857/ https://nvd.nist.gov/vuln/detail/CVE-2026-33857

Identificativo/ Livello:	CVE-2013-5704– CVSS v2.0: 5.0/10 (Medium)
Descrizione:	Il modulo mod_headers nel server HTTP Apache 2.2.22 consente ad aggressori remoti di aggirare le direttive "RequestHeader unset" inserendo un'intestazione nella parte finale dei dati inviati con codifica di trasferimento a blocchi (chunked transfer coding).
Impatto:	Un attaccante può bypassare controlli sugli header HTTP o alterare il comportamento della richiesta, con possibile impatto su integrità delle richieste e controlli di sicurezza.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.12 o successiva e, se necessario, abilitare correttamente la direttiva MergeTrailers per gestire in modo sicuro i trailer HTTP.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2013-5704/ https://nvd.nist.gov/vuln/detail/CVE-2013-5704

Identificativo/ Livello:	CVE-2014-3583– CVSS v2.0: 5.0/10 (Medium)
Descrizione:	La funzione handle_headers nel file mod_proxy_fcgi.c del modulo mod_proxy_fcgi del server HTTP Apache 2.4.10 consente ai server FastCGI remoti di causare un denial of service (overread del buffer e crash del demone) tramite intestazioni di risposta lunghe.
Impatto:	Può causare un Denial of Service (crash del server Apache) e, in alcuni casi, possibile lettura di dati in memoria (impatto su disponibilità e parzialmente riservatezza).
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.12 o successiva, che corregge la vulnerabilità
Detection:	Analisi manuale

Riferimenti:	https://www.cvedetails.com/cve/CVE-2014-3583/ https://nvd.nist.gov/vuln/detail/CVE-2014-3583
--------------	--

Identificativo/ Livello:	CVE-2015-0228 – CVSS v2.0: 5.0/10 (Medium)
Descrizione:	La funzione lua_websocket_read presente nel file lua_request.c del modulo mod_lua del server HTTP Apache fino alla versione 2.4.12 consente ad aggressori remoti di causare un denial of service (arresto anomalo del processo figlio) inviando un frame WebSocket Ping appositamente creato dopo che uno script Lua ha chiamato la funzione wsupgrade.
Impatto:	Un attaccante remoto può causare crash di un processo figlio di Apache, provocando interruzione del servizio (DoS).
Soluzione:	Aggiornare Apache HTTP Server oltre la versione 2.4.12 (o applicare le patch di sicurezza) ed evitare o limitare l'uso di mod_lua/WebSocket se non necessario.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2015-0228/ https://nvd.nist.gov/vuln/detail/CVE-2015-0228

Identificativo/ Livello:	CVE-2014-8109 – CVSS v2.0: 4.3/10 (Medium)
Descrizione:	Il file mod_lua.c nel modulo mod_lua del server HTTP Apache 2.3.x e dalla versione 2.4.x fino alla 2.4.10 non supporta una configurazione httpd in cui lo stesso provider di autorizzazione Lua viene utilizzato con argomenti diversi in contesti diversi, il che consente ad aggressori remoti di aggirare le restrizioni di accesso previste in circostanze opportunistiche sfruttando più direttive Require, come dimostrato da una configurazione che specifica l'autorizzazione per un gruppo ad accedere a una determinata directory e l'autorizzazione per un secondo gruppo ad accedere a una seconda directory.
Impatto:	Un attaccante può bypassare restrizioni di accesso, ottenendo accesso non autorizzato a risorse protette (impatto su integrità e riservatezza).
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.12 o successiva, che corregge la gestione delle direttive Lua e dei controlli di autorizzazione.
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2014-8109/ https://nvd.nist.gov/vuln/detail/CVE-2014-8109

Identificativo/ Livello:	CVE-2015-3185– CVSS v2.0: 4.3/10 (Medium)
Descrizione:	La funzione ap_some_auth_required nel file server/request.c del server HTTP Apache 2.4.x precedente alla versione 2.4.14 non considera che una direttiva Require possa essere associata a un'impostazione di autorizzazione anziché a un'impostazione di autenticazione, il che consente ad aggressori remoti di aggirare le restrizioni di accesso previste in circostanze opportunistiche, sfruttando la presenza di un modulo che si basa sul comportamento dell'API 2.2.
Impatto:	Un attaccante può bypassare alcune restrizioni di accesso, ottenendo accesso non autorizzato a risorse che dovrebbero essere protette (impatto su integrità e riservatezza).
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.14 o successiva, dove il problema è stato corretto, oppure rivedere la configurazione dei moduli di autenticazione per evitare comportamenti incoerenti tra direttive di accesso
Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2015-3185/ https://nvd.nist.gov/vuln/detail/CVE-2015-3185

Identificativo/ Livello:	CVE-2016-8612 – CVSS v3.0: 4.3/10 (Medium)
Descrizione:	Il server HTTP Apache mod_cluster, nelle versioni precedenti alla 2.4.23 di httpd, è vulnerabile a una convalida impropria dell'input nella logica di analisi del protocollo nel bilanciatore di carico, che causa un errore di segmentazione nel processo httpd di servizio.
Impatto:	Un attaccante remoto può provocare un Denial of Service (DoS) facendo andare in crash Apache, con interruzione del servizio.
Soluzione:	Aggiornare Apache HTTP Server alla versione 2.4.23 o successiva, che corregge il problema nel modulo mod_cluster.

Detection:	Analisi manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2016-8612/ https://nvd.nist.gov/vuln/detail/CVE-2016-8612

6.4 VULNERABILITÀ CLASSIFICATE: LOW

Le vulnerabilità classificate **LOW** sono:

Identificativo/ Livello:	CVE-1999-0524 / CVSS v2.1: 2.1/10 (Low)
Descrizione:	Le informazioni ICMP come (1) netmask e (2) timestamp sono consentite da host arbitrari.
Impatto:	Permette a un attaccante remoto di raccogliere dati utili per attività di reconnaissance e attacchi successivi.
Soluzione:	Le mitigazioni includono bloccare le richieste ICMP di tipo timestamp (13) e timestamp reply (14) e filtrare ICMP non necessari tramite firewall.
Detection:	Nessus
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-1999-0524 https://www.cve.org/CVERecord?id=CVE-1999-0524

Identificativo/ Livello:	CVE-2021-36368 / CVSS v3.1: 3.7/10 (Low)
Descrizione:	È stato scoperto un problema in OpenSSH prima della versione 8.9. Se un client utilizza l'autenticazione con chiave pubblica con inoltro dell'agente ma senza -oLogLevel=verbose e un utente malintenzionato ha modificato silenziosamente il server per supportare l'opzione di autenticazione None, l'utente non può determinare se l'autenticazione FIDO confermerà la sua volontà di connettersi a quel server o se consentirà a quel server di connettersi a un server diverso per suo conto.
Impatto:	L'impatto reale è limitato, perché non permette un vero bypass diretto dell'autenticazione. Può però causare confusione dell'utente o interpretazioni non chiare del processo di login, con un impatto soprattutto su riservatezza e sicurezza operativa, ma classificato come basso.
Soluzione:	Aggiornare OpenSSH alla versione 8.9 o successiva e mantenere il client SSH aggiornato; inoltre è consigliato evitare configurazioni con agent forwarding non necessario.
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2021-36368 https://www.cvedetails.com/cve/CVE-2021-36368/

Identificativo/ Livello:	CVE-2025-61984 / CVSS v3.1: 3.6/10 (Low)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 10.1, il protocollo ssh consentiva l'utilizzo di caratteri di controllo nei nomi utente provenienti da determinate fonti potenzialmente non attendibili, il che poteva portare all'esecuzione di codice arbitrario quando si utilizzava un ProxyCommand. Le fonti non attendibili sono la riga di comando e l'espansione della sequenza % di un file di configurazione.
Impatto:	Un attaccante può sfruttare questa condizione per alterare il comportamento del comando SSH e, in alcuni scenari specifici, arrivare a esecuzione di comandi locali (RCE) sul sistema client. Tuttavia l'impatto reale è considerato basso, perché richiede condizioni particolari di configurazione e interazione
Soluzione:	Aggiornare OpenSSH alla versione 10.1 o successiva.
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2025-61984 https://www.cvedetails.com/cve/CVE-2025-61984/

Identificativo/ Livello:	CVE-2025-61985 / CVSS v3.1: 3.6/10 (Low)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 10.1, il carattere '\0' era presente negli URI ssh://, il che poteva potenzialmente portare all'esecuzione di codice quando si utilizzava un ProxyCommand.
Impatto:	L'impatto è considerato basso, ma in configurazioni particolari può consentire alterazioni del comportamento del client SSH e potenziale esecuzione di comandi locali, quindi un rischio

	principalmente legato a integrità e sicurezza operativa.
Soluzione:	Aggiornare OpenSSH alla versione 10.1 o successiva.
Detection:	Analisi Manuale
Riferimenti:	https://nvd.nist.gov/vuln/detail/CVE-2025-61985 https://www.cvedetails.com/cve/CVE-2025-61985/

Identificativo/ Livello:	CVE-2026-35388 / CVSS v3.1: 2.5/10 (Low)
Descrizione:	Nelle versioni di OpenSSH precedenti alla 10.3, la conferma del multiplexing della connessione viene omessa per le sessioni con multiplexing in modalità proxy.
Impatto:	L'impatto è basso: in condizioni specifiche può causare comportamenti anomali nelle connessioni SSH multiplexate o lievi modifiche nel flusso della sessione, ma non consente esecuzione di codice o accesso non autorizzato diretto.
Soluzione:	Aggiornare OpenSSH alla versione 10.3 o successiva.
Detection:	Analisi Manuale
Riferimenti:	https://www.cvedetails.com/cve/CVE-2026-35388/ https://www.cvedetails.com/cve/CVE-2026-35388/

Identificativo/ Livello:	Cross-Domain JavaScript Source File Inclusion / CWE-829
Descrizione:	La debolezza si verifica quando una pagina web include file JavaScript ospitati su domini esterni non completamente affidabili. Questo può introdurre codice potenzialmente malevolo all'interno dell'applicazione.
Impatto:	Possibile esecuzione di codice JavaScript non controllato all'interno del browser dell'utente, con rischio di furto di dati, manipolazione del contenuto della pagina o attacchi di tipo XSS tramite supply chain esterna.
Soluzione:	Limitare l'inclusione di script a fonti affidabili e controllate, utilizzare Subresource Integrity (SRI) e, quando possibile, ospitare localmente le librerie JavaScript critiche.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/829.html

Identificativo/ Livello:	In Page Banner Information Leak / CWE-497
Descrizione:	La debolezza consiste nella presenza di informazioni sensibili o dettagli tecnici all'interno della pagina web (banner, messaggi di errore o header visibili), che possono rivelare dati interni dell'applicazione o dell'infrastruttura.
Impatto:	Possibile divulgazione di informazioni utili a un attaccante, come dettagli su server, tecnologie utilizzate o configurazioni interne, facilitando attacchi mirati.
Soluzione:	Rimuovere o limitare le informazioni tecniche esposte all'utente, configurando messaggi di errore generici e disabilitando la visualizzazione di dettagli interni in ambienti di produzione.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/497.html

Identificativo/ Livello:	Server Leaks Version Information via "Server" HTTP Response Header Field / CWE-497
Descrizione:	La debolezza consiste nell'esposizione della versione del server web tramite l'header HTTP "Server". Questo comportamento rivela informazioni dettagliate sul software in uso, come tipo e versione del web server.
Impatto:	Possibile divulgazione di informazioni utili a un attaccante per identificare vulnerabilità specifiche del server in base alla versione esposta, facilitando attacchi mirati.
Soluzione:	Configurare il server per ridurre o nascondere le informazioni della versione nell'header "Server" (ad esempio tramite direttiva ServerTokens su Apache) e limitare i dettagli esposti nelle risposte HTTP.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/497.html

Identificativo/ Livello:	X-Content-Type-Options Header Missing / CWE-693
--------------------------	---

Descrizione:	La debolezza consiste nell'assenza dell'header HTTP X-Content-Type-Options, che impedisce al browser di interpretare i file con MIME type diverso da quello dichiarato. Senza questo controllo, il browser può effettuare "MIME sniffing".
Impatto:	Possibile esecuzione di contenuti malevoli se il browser interpreta erroneamente il tipo di file, con rischio di attacchi XSS o caricamento di contenuti non sicuri.
Soluzione:	Impostare l'header X-Content-Type-Options: nosniff nelle risposte HTTP per impedire il MIME sniffing e garantire il rispetto del Content-Type dichiarato.
Detection:	OWASP ZAP
Riferimenti:	https://cwe.mitre.org/data/definitions/693.html

References

[1] CVE Details – Apache HTTP Server 2.4.10 Vulnerability List. [Online]. Available: https://www.cvedetails.com/vulnerability-list/vendor_id-45/product_id-66/version_id-529730/Apache-Http-Server-2.4.10.html?page=1&order=3

[2] CVE Details – OpenSSH 6.7 Vulnerability List. [Online]. Available: https://www.cvedetails.com/vulnerability-list/vendor_id-97/product_id-585/version_id-547565/Openbsd-Openssh-6.7.html?page=2&order=1

[3] National Vulnerability Database (NVD), «CVE-2016-10033 Detail». [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2016-10033>

[4] Acunetix, «WordPress 4.8.x Multiple Vulnerabilities (4.8 – 4.8.7)», Vulnerability Database. [Online]. Available: <https://www.acunetix.com/vulnerabilities/web/wordpress-4-8-x-multiple-vulnerabilities-4-8-4-8-7/>